Understanding the Privacy-Preserving Potential of HTTP/2 Against Webpage Fingerprinting

Full version of the paper accepted at ACM CCS 2026; includes extended appendices. Please cite the conference version.

Bogdan Cebere
bogdan.cebere@cispa.de
CISPA Helmholtz Center for Information Security
Dortmund, Germany

Prateek Kumar
prateek21081@iiitd.ac.in
CISPA Helmholtz Center for Information Security
Saarbrücken, Germany

Sylvain Chatel
sylvain.chatel@cispa.de
CISPA Helmholtz Center for Information Security
Saarbrücken, Germany

Wouter Lueks
lueks@cispa.de
CISPA Helmholtz Center for Information Security
Saarbrücken, Germany

Christian Rossow
rossow@cispa.de
CISPA Helmholtz Center for Information Security
Dortmund, Germany

arXiv:2609.05119v1 [cs.CR] 4 Sep 2026

Abstract

Website fingerprinting (WF) attacks can infer which webpage a user visits from encrypted HTTPS traffic alone, compromising privacy even without decryption. WF defenses commonly shape traffic through noise, padding, delays, or flow splitting — yet they are most often studied from the perspective of encapsulating protocols like Tor or VPN rather than at the application layer (HTTP).

In this work, we focus on application-layer defenses enabled by the most widely deployed version of HTTP — HTTP/2. We demonstrate how known defenses can be emulated through HTTP/2 features at the client side (HTTPOS, LLaMA, FRONT, Tamaraw) and the server side (ALPaCA, Tamaraw). We further show that HTTP/2 features — such as proactive resource suggestion, multiplexing, and flow control — offer untapped potential for lightweight yet effective defenses deployable at both endpoints.

We evaluate these defenses using a unified blueprint that calibrates defense parameters per dataset, then combines practical attacks, information-theoretic leakage estimates, and overhead measurements. For each defense, this framework identifies the strongest hyperparameter-tuned fingerprinting model and estimates the residual uncertainty induced by the defense using two information-theoretic leakage estimators — all while accounting for the defense's privacy–overhead trade-offs.

CCS Concepts

• **Security and privacy** → **Web protocol security**; • **Computing methodologies** → *Machine learning*.

Keywords

Website Fingerprinting, Machine Learning, HTTP/2

1 Introduction

Website fingerprinting is a traffic analysis technique that enables adversaries to infer users' online activities — such as political or social behavior — and to facilitate adversarial behavior, including censorship and targeted surveillance. Website fingerprinting remains feasible despite the widespread deployment of HTTP over TLS (i.e., HTTPS), since TLS encrypts only the application payload, leaving network- and transport-layer headers and traffic characteristics (packet sizes, timings, and ordering) observable to on-path adversaries. Website fingerprinting leverages this residual metadata to reconstruct browsing patterns and compromise user privacy.

In response, fingerprinting defenses aim to make the IP/TCP/UDP metadata uninformative. Popular obfuscation techniques rely on the Tor and VPN protocols, which encapsulate traffic and obscure its content from on-path observers. However, most web traffic does not use Tor or VPN, leaving HTTP packet metadata directly exposed to on-path adversaries such as ISPs or network operators. For this reason, we focus on fingerprinting scenarios that can be defended by clients or servers at the application-layer (HTTP).

Application-layer fingerprinting defenses generally pursue one of two strategies: (1) uniformity, wherein the defense transforms webpage metadata into fixed packet lengths and rates; or (2) unpredictability, wherein the defense ensures that metadata differs across subsequent page loads. To follow these strategies, fingerprinting defenses commonly rely on four obfuscation functionalities: (1) noise traffic insertion, (2) packet padding, (3) packet delay, and (4) packet splitting [63]. These mechanisms do not hide IP-layer metadata or the destination domain and therefore complement (not replace) Tor or VPN solutions when network-layer anonymity is required. Instead, they target subpage fingerprinting over ordinary HTTPS by perturbing transport-visible features such as packet sizes, timing, and ordering, thereby reducing leakage about the specific content accessed within a known domain. This distinction is relevant when the domain itself is not sensitive, but the visited subpage is, such as a particular product or medical page.

The privacy potential of modern HTTP-layer features like multiplexing, reprioritization, and flow control has not been fully explored yet. Prior work has shown that established fingerprinting defenses can be emulated in HTTP/3 [63], but no equivalent study exists for HTTP/2. This gap is practically important: as of 2026, HTTP/2 remains the predominant deployed HTTP version, accounting for approximately 60% of browser traffic, compared with roughly 31% for HTTP/3 [4, 13]. Thus, HTTP/2 is not merely a legacy target, but the protocol on which the majority of today's Web traffic still depends.

Moreover, the HTTP/2 defenses are more challenging to design, as TCP's flow control is typically handled by the OS kernel, whereas QUIC (HTTP/3) implementations commonly run in userspace, allowing applications more direct control over flow-control–driven traffic shaping. Beyond emulating existing defenses, HTTP/2 also opens the door to new strategies — such as leveraging proactive resource hints or stream multiplexing — but this potential likewise remains largely unexplored.

Before such defenses can be meaningfully assessed, we must first confront a fundamental challenge: *how to measure whether they truly provide privacy*. Evaluating defenses is inherently harder than evaluating attacks. While attacks can often succeed with a single model and dataset, defenses must be tested against multiple adversaries to establish credible security guarantees. Yet the common practice of reporting reduced fingerprinting accuracy under defense can be misleading, as degradation may also result from preprocessing errors, poor hyperparameter tuning, or near-misses by attackers. Prior work has proposed complementary techniques, including privacy-overhead calibration curves [7] and model-agnostic estimators of information leakage [10, 31, 67]. Building on these ideas, we propose a unified framework that calibrates each defense per dataset to select a practical privacy–overhead operating point, then stress-tests the selected configuration against hyperparameter-tuned attackers and leakage estimators.

Contributions. This paper explores how HTTP/2 can be harnessed for website fingerprinting defenses. Our contributions are threefold:

(1) **Evaluation framework**. We introduce a benchmarking blueprint for assessing the quality of fingerprinting defenses that unifies practical attacks, information-theoretic leakage estimates, and overhead measurement (Section 4). For each defense, the framework calibrates its operating parameters per dataset, evaluates its privacy–overhead trade-off, identifies the strongest hyperparameter-tuned attack, and measures the residual leakage that remains.

(2) **Defense emulation.** We demonstrate how established defenses — both client-side [7, 11, 23, 38] and server-side [7, 11] — can be reproduced using HTTP/2 primitives, and evaluate their effectiveness on real-world case studies using our framework (Section 5). The results show substantial but dataset-dependent privacy gains: even the strongest attackers cannot narrow the set of plausible webpages to fewer than 26 candidates on four of five datasets with client-side defenses, or fewer than 63 candidates on any dataset with appropriately placed server-side defenses, whether at the 1st-party server, CDN, or across all involved servers.

(3) **New opportunities.** We explore untapped HTTP/2 features for privacy, highlighting novel defense strategies such as client-side multiplexing and server-side proactive resource suggestion (Section 6). These client-side techniques provide more consistent protection across datasets, keeping the attacker's estimated candidate set above seven webpages in *all* five cases, while reducing latency overhead by 55–98% and downstream overhead by 20–66%. On the server side, HTTP/2 enables the 1st-party server to deploy defenses without controlling all content-delivery servers, keeping the plausible candidate set above 13 webpages across all datasets while reducing bandwidth overhead by 54–80% on most datasets.

2 Threat Model and Attacker Goals

We consider a passive on-path adversary with access to the TCP layer, who attempts to determine the visited webpage from an encrypted HTTP/2 traffic trace by analyzing traffic characteristics such as packet lengths, inter-arrival times, and ordering. We assume the adversary can observe individual TCP connections during a page load (one per subdomain involved in the page load), grouping them into a single *trace* while keeping each connection identifiable.

We assume the adversary cannot alter the communication – i.e., they do not actively intercept the communication using Machine-in-the-Middle attacks. This scenario is common (e.g., Internet or VPN providers observing communication) and more stealthy — no need to install custom certificates on the client. However, we also assume a defense-aware adversary who knows which defense mechanism is deployed and can collect labeled defended traces for training.

We focus on *subpage fingerprinting*: identifying which specific subpage of a known domain a user visits — for example, the exact Amazon product page, the particular BBC article, or the specific Reddit thread. In this setting, all contacted subdomains during webpage load are already observable via IP addresses, DNS resolves, and TLS handshakes. In principle, the sequence of subpage-specific DNS lookups and TLS SNI values for third-party services (e.g., CDNs) could additionally leak subpage identity, but such leakage is orthogonally mitigated by DNS-over-HTTPS (DoH) [26] or Encrypted Client Hello (ECH) [52]. Specific to our empirical studies, assuming legacy clients without these features, DNS contact ordering alone yields near-random subpage classification on four of five datasets ($F1 \leq 0.10$), as we show empirically in Section 3.2.3. The HTTP layer, therefore, remains the primary actionable source of leakage in our threat model and the only one that application-layer HTTP/2 defenses can address. Note that DoH and ECH can mitigate DNS/SNI leakage, but do not mitigate subpage fingerprinting as studied here.

3 Website Fingerprinting

To motivate the need for HTTP/2 privacy techniques, we first introduce established website fingerprinting techniques (Section 3.1), then apply them on real-world sensitive case studies (Section 3.2).

3.1 Fingerprinting Techniques

In website fingerprinting, an observer attempts to extract sensitive information from encrypted communication by using network-layer information (e.g., IP addresses), transport-layer metadata (e.g., TCP segment sizes, connection counts), and derived traffic statistics (e.g., throughput, inter-packet timing, burst patterns) [8, 9, 19, 24, 25, 30, 46, 58, 64]. This metadata is used to find the most similar page in an already-collected training set using Machine-Learning methods. Previous website fingerprinting works explored the potential of Gaussian Distributions [41], linear models [14], random forests [35], clustering methods [24, 59], and neural networks (NN) [5, 16–18, 34, 36, 57, 60, 62, 66, 73]. Most prior works focus on domain fingerprinting (using as labels the hosting domain, e.g., google.com or fb.com) under Tor encapsulation; some also explore the subpage-fingerprinting problem [60, 74, 75]. In contrast to these works on subpage WF, our work focuses on subpage-WF in HTTP/2 (previously discussed only in [74] on multiplexing effect).

3.1.1 ***Fingerprinting Models.*** For the attacker effectiveness benchmarks, we evaluate each dataset against five fingerprinting models: (1) *k-FP* [24], which combines *k*-nearest neighbor clustering with a Random Forest; (2) *Deep Fingerprinting (DF)* [62], a CNN-based architecture that operates directly on raw traces; (3) *VarCNN* [5], a ResNet-style architecture designed to capture multi-scale burst patterns; (4) *Holmes* [18], which combines spatial–temporal pattern analysis with contrastive learning to identify websites before the page fully loads; (5) *Robust-Fingerprinting (RobustFP-CNN)* [58], for which we reuse only the CNN classifier architecture, applying 2D convolutions over local packet windows to jointly capture packet-size and timing patterns in defended traces. We do not use RF's time-aggregated representation, which improves robustness to padding but would discard the informative variable packet lengths present in our HTTP/2 traces; consequently, RobustFP-CNN does not evaluate the full RF approach.
Note: All WF models above were originally developed for Tor traffic; in contrast, in our benchmarks, the packet lengths are also informative (compared to constant-size Tor cells), and omitting them would artificially cripple the models. *Therefore, the benchmarks are executed on different dataset types and features than those in the related work.* Implementation details in Section E.

3.1.2 ***Dataset Creation.*** Throughout the empirical studies, we evaluate HTTP/2 defenses from both client and server perspectives, requiring control over both endpoints while replaying the same real webpage resources. For each webpage, we first collect and cache browser requests and responses, including headers and body content (Section D.1), then replay them through a custom Python client-server with defenses enabled or disabled, (Section D.2) and capture the resulting PCAP traces (Section D.3). This replay setup is necessary to evaluate server-side defenses under identical content, enable same-resource comparisons, and isolate HTTP/2-layer effects from content and network-path variability. The resulting measurements therefore characterize defense-induced changes rather than live-Web variability: browser/CDN scheduling and resource dependencies are not reproduced, which may affect latency and intra-page variance but does not undermine the controlled comparison targeted by our study. Each PCAP trace is represented as a collection of connections, where each connection is a sequence of packet lengths, inter-arrival timings, and directions.

For every webpage and defense scenario, we generate 500 defended PCAP traces, independently resampling all randomized defense choices for each replay. Under five-fold cross-validation, each attacker is therefore trained on approximately 400 defended realizations per webpage. This provides hundreds of directly measured realizations of the defense-induced distribution for every class, so additional synthetic augmentation is not needed to compensate for limited training diversity. Moreover, artificially perturbing packet sizes or timings could introduce traces that deviate from the traffic distribution produced by the evaluated defense.

The traces are converted into two distinct evaluation datasets: a 2D representation (for k-FP), and a 3D representation (for DF, VarCNN, Holmes, and RobustFP-CNN models). k-FP operates on handcrafted per-connection statistics: packet counts and unique sizes per direction; top-*N* burst size statistics; cumulative incoming/outgoing byte totals interpolated to a fixed-length vector; and inter-arrival timing statistics. Each trace is first converted to an array of statistics, and the final dataset is a matrix of shape (n_traces, $\mathrm{LIM}_{\mathrm{conns}} *$ n_features). In our datasets, the bulk of the leakage is concentrated in at most three connections, so we set $\mathrm{LIM}_{\mathrm{conns}} = 3$. The neural network models operate on a raw 3D time-series tensor with two channels: signed packet lengths (positive for upload, negative for download) and inter-arrival times. This differs from the original NN model designs [5, 18, 62], which were built for Tor traffic where cell sizes are fixed and only direction, counts, and inter-arrival times are informative. We therefore include packet lengths as a dedicated channel in the tensor representation, acknowledging that this is not a direct architectural comparison but rather an adaptation to the richer information available at the TCP layer. Within each trace, connection blocks are concatenated in arrival order, ordered by the timestamp of each connection's first packet. Inter-arrival times are recorded relative to the start of each connection, so the timestamp resets to zero at every connection boundary; this acts as an implicit connection-boundary signal that the model can learn from. Following prior work [5, 51, 53, 62], we treat the maximum trace length L as a hyperparameter and set $L = 5000$ packets, which does not truncate any trace in our benchmarks. Each model outputs a probability distribution over the N webpages in the training set.

3.1.3 ***Fingerprinting Benchmarks.*** The primary objective of the fingerprinting benchmarks is *to assess the effectiveness of the attacker*, represented by the fingerprinting model. Given C website classes, we evaluate each model using cross-validation $F1_c = 2\mathrm{TP}_c/(2\mathrm{TP}_c + \mathrm{FP}_c + \mathrm{FN}_c)$ and report Macro-F1 $= C^{-1}\sum_{c=1}^{C} F1_c$, where TP_c, FP_c, and FN_c denote the true positives, false positives, and false negatives for website c, respectively. For each benchmark, we report the mean score and the 95% confidence interval (mean $\pm\mathrm{CI}_{95\%}$) across all folds. As a rule of thumb, when using $C = 100$ classes, the macro-F1 value is ~ 0.01 for random guesses, $\sim 0.1-0.5$ for weak attackers, and 0.8+ for strong attackers.

3.1.4 ***Datasets Types.*** We investigate website fingerprinting against users who browse without additional encapsulation layers such as Tor or VPN. Most website fingerprinting research focuses on *domain-level* inference — determining which domain a user visits — using datasets such as Tranco or Alexa [12, 40, 41, 46, 48]. To avoid trivial leakage via TLS certificates or IP addresses, these studies typically assume clients use anonymity systems like Tor or VPN, which conceal both endpoints and traffic features. In contrast, *subpage fingerprinting* seeks to identify which specific subpage of a known domain a user visits (e.g., a product page on Amazon). This setting is more fine-grained, as subpages usually share similar DNS, TLS, and IP traits, leaving most differences at the HTTP layer.

These architectural differences also influence how defenses behave. In Tor or VPN, a passive observer sees a single long-lived tunnel that encapsulates all TLS connections. Thus, a defense applied to any one TLS connection modifies the metadata of the entire tunnel — for example, protected traffic from one connection may overlap with the TLS handshake of another. In contrast, with plain HTTPS (without Tor or VPN), each connection is exposed individually — therefore, it must be protected independently. Since our work targets plain HTTPS traffic, we focus on subpage-fingerprinting case studies to evaluate *application-layer defenses.*

Table 1: Real-world datasets and their average number of unique servers, requests, the image count, and their sizes.

Dataset	# Servers Used per Page	# Avg. Req. per Conn.	# Avg. Images per Page	Avg. Image Size (KB)
Amazon	4.14 ± 0.1	19.3 ± 1.2	29.22 ± 1.5	101.8 ± 17.2
BBC	8.03 ± 0.1	6.97 ± 0.3	12.8 ± 16.3	197.04 ± 173.4
Reddit	8.21 ± 0.1	6.87 ± 0.2	10.66 ± 0.2	84.71 ± 20.5
Udemy	2.03 ± 0.1	5.72 ± 0.1	8.75 ± 1.3	16.38 ± 4.4
Wiki	3.83 ± 0.1	8.14 ± 0.3	15.42 ± 0.7	32.16 ± 1.4

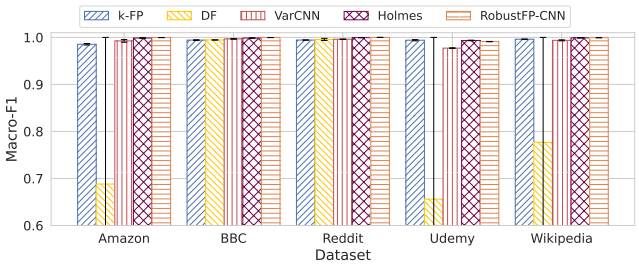


Figure 1: Fingerprinting performance (F1 score) on the undefended real-world datasets.

3.2 Fingerprinting Case Studies

We now discuss five fingerprinting case studies and their privacy risks. These results will lay the foundation for the defensive benchmarks in the following sections.

3.2.1 ***Datasets.*** We collect 100 subpages from five public websites — Amazon, BBC, Reddit, Udemy, and Wikipedia — as balanced datasets with 500 samples per page — using the steps detailed in Section 3.1.2. These five websites are case studies rather than a representative sample of the Internet, chosen to capture variation in sensitive connections, requests per connection, and image counts. This diversity is central to our analysis: both the calibrated defense parameters and the strongest hyperparameter-tuned attackers vary across datasets (Section 5.3), showing that defense effectiveness is structure-dependent and that no single configuration is universally representative. We therefore evaluate multiple websites to capture dataset-dependent defense behavior rather than draw general conclusions from a single dataset. To assess the effectiveness of fingerprinting defenses, we focus on *closed-world scenarios*, where the attacker has full knowledge of all target pages. This setting is intentionally chosen because it represents the most challenging case to defend, and an *upper bound on attacker accuracy*.

Table 1 summarizes some of the per-webpage statistics of each dataset: the average number of servers contacted per webpage, the average request count per connection, and the average image size observed in each webpage for each dataset. Per page load, each connection is a sequence of requests (e.g., images, script downloads) and can create a fingerprinting side-channel (alone or combined with other connections). Due to larger resource-specific sizes, images are a primary source for fingerprinting, as previous studies also analyzed [8, 68], and thus we report their statistics separately.

3.2.2 ***Fingerprinting on the Undefended Datasets.*** Figure 1 summarizes the fingerprinting performance of each model across the five datasets. We observe that, for every dataset, multiple hypertuned fingerprinting architectures achieve a macro-F1 score ≥ 0.9, indicating high webpage-identification accuracy. In particular, strong performance is achieved by both feature-engineered approaches such as k-FP, which rely on global traffic statistics, and deep-learning approaches that learn representations directly from packet sequences. Overall, these results show that an effective defense must mitigate both feature-engineered and deep-learning-based fingerprinting attacks.

Intuitively, leakage sources group into: *packet counts*, *timing/IAT* (inter-arrival times), *bursts* (how data is grouped, e.g., initial HTML followed by resources), and *CUMUL* (the overall growth of the transfer, such as how upload or download bytes accumulate over time). Manual inspection shows per-site fingerprints resulted from:

- Amazon: number, size, and IATs of image requests to third-party CDNs (`media-amazon`, `ssl-images-amazon`).
- BBC: IAT, burst, and CUMUL across ≥ 2 connections — first-party plus a CDN (`static.files.bbci`).
- Reddit: burst and CUMUL on first-party and a CDN (`redditmedia`).
- Udemy: burst and CUMUL, almost entirely on the first-party connection (`www.udemy.com`).
- Wikipedia: first-party (`wikipedia.org`) dominates — packet counts, bursts, and CUMUL from image downloads.

3.2.3 ***Scope of Leakage: `HTTP` vs. Sequence of Domains (`DNS` or SNI).*** `HTTP/2` is not, in itself, sufficient to protect the subpage's identity. For legacy clients — without DoH or ECH support — the target webpage may also be visible through other channels, such as the sequence of plaintext `DNS` queries or `TLS` SNI within the webpage load. To assess whether `DNS` contact ordering alone enables fingerprinting, we encoded the sequence of contacted domain names during webpage load as features and trained a k-FP classifier on the dataset. The resulting macro-F1 scores are: Amazon 0.10, BBC 0.07, Reddit 0.74, Udemy 0.01, Wikipedia 0.03. `DNS` contact ordering is therefore largely uninformative for subpage identity across four of five datasets. Reddit is the only outlier, likely due to its large number of *unique* servers per subpage (8.21 ± 0.1, Table 1), which causes subpage-specific TLS handshakes. BBC, despite a similarly large server count (8.03 ± 0.1), contacts largely the same servers across subpages, leaving `DNS` uninformative. Since `HTTP/2` application-layer defenses cannot address `DNS` or `TLS` leakage — that requires orthogonal mechanisms such as DoH or ECH — we treat Reddit's `DNS` leakage as a known limitation and focus our defenses on the `HTTP` packet-level side channel, which dominates in four of five datasets.

Takeaways. We presented five datasets that exhibit diverse fingerprinting leakage characteristics: (i) some exhibit at least one dominant leaking subdomain/connection (Amazon, Udemy, Wikipedia); (ii) others involve multiple connections contributing to page identification (Reddit, BBC); (iii) certain datasets contain informative packet counts (Amazon, Wikipedia); (iv) some datasets leak information through processing duration (Amazon, BBC); and (v) all exhibit leakage through CUMUL and burst statistics. Any successful fingerprinting defense must address all of these side channels.

4 Benchmarking WF Defenses

Defense benchmarks aim to quantify how closely any attacker could infer the correct website. However, relying solely on fingerprinting accuracy (Section 3.1.3) can be misleading: a defense may only defeat specific models or provide privacy at the cost of impractically high overhead. Moreover, implementation errors such as faulty preprocessing or incorrect feature scaling can artificially lower an attacker's performance, creating a false sense of security.

To address these pitfalls, we propose a novel Blueprint for Benchmarks and Quality Assurance (BBQ) of fingerprinting defenses. The framework calibrates each defense and evaluates it using five practical attackers (k-FP, DF, VarCNN, RobustFP-CNN, Holmes), information-theoretic leakage estimates from two security estimators (WeFDE [31] and DeepSE-WF [67]), and the privacy–overhead trade-off. We provide takeaways of our benchmarking blueprint at the end of Section 4.

BBQ 0 **Defense calibration**: *Which defense configuration is recommended for this website and the underlying protocol (here:* HTTP/2*)?*
Defense parameters inherited from prior protocols may not transfer directly to HTTP/2, and multiple parameters may jointly affect privacy and overhead. We therefore define and evaluate several defense configurations at increasing intensity levels. Cai et al. [7] similarly evaluated privacy–overhead trade-offs across defense parameter settings; however, their defenses were applied offline to packet sequences, whereas we implement each configuration in HTTP/2 and generate defended traces by replaying real webpages.

Using a calibration set containing 100 traces per webpage, we characterize each configuration by the maximum Macro-F1 across the five practical attackers in BBQ 1, together with bandwidth and latency overheads measured as in BBQ 4. We refer to this maximum as the *calibration Macro-F1*. For each dataset, we then select a practical operating point from the observed privacy–overhead curve, favoring configurations that provide substantial reductions in calibration Macro-F1 while avoiding higher-intensity settings whose additional overhead yields limited privacy improvement. The selected defense parameters are then fixed and evaluated under BBQ 1–4 on a separately generated dataset containing 500 traces per webpage.

BBQ 1 **Practical Attacker Effectiveness:** *How accurately does an attacker perform against the defense?*
For each defense, we measure and report the maximum Macro-F1 score (Section 3.1.3) of the fingerprinting models introduced in Section 3.1.1 — the "baseline resilience" of each defense. Each attacker is hyperparameter-tuned independently for the corresponding dataset–defense pair, retaining its default configuration when tuning does not improve validation Macro-F1. Intuitively, the macro-F1 value is $\sim 0.1 - 0.6$ for strong defenses (against the evaluated attacker), and 0.8+ for a weak defense.

BBQ 2 **Practical Attacker Predictive Proximity:** *How close are the attackers to the correct answer?*
The F1 scores hide if a model "almost" predicted a perfect match. Using the same tuned attacker configurations as in BBQ 1, we therefore also report Top-k accuracy to measure an attacker's proximity to the correct answer, i.e., the fraction of traces for which the correct website y_i appears among the k highest-scoring predictions:

$$\text{Top-}k \text{ Accuracy} = \frac{1}{N}\sum_{i=1}^{N} \mathbf{1}[\, y_i \in \text{TopK}(p_i, k)\,],$$

where $\mathbf{1}[\cdot]$ is the indicator function and p_i is the scoring prediction. A score of 0.9 means the attacker correctly identifies the correct page within their top k predicted candidates in 90% of the cases.

BBQ 3 **Theoretical Attacker Uncertainty under Optimal Conditions:** *How much uncertainty does the defense induce in an ideal attacker's predictions?*
Fingerprinting defenses can be tuned to evade known ML techniques, creating a false sense of security — that is, BBQ 1–2 remain tightly coupled to specific fingerprinting models and may fail to capture the full leakage potential present in the traffic traces. To overcome this limitation, we measure *the model-agnostic uncertainty* — not just classification errors — using information-theoretic methods directly on the datasets. We characterize the defense's impact on the attackers through the prior and the conditional entropies:

$$H(Y) = -\sum_{y} p(y)\,\log_2 p(y), \quad H(Y \mid X) = \mathbb{E}_x\big[H\big(P(Y \mid X{=}x)\big)\big].$$

where X is the (defense-processed) traffic representation and Y the page label. $H(Y)$ quantifies the uncertainty about the webpage before observing the traffic, while $H(Y \mid X)$ measures the uncertainty about webpage Y after observing the features X (model agnostic). Using these entropies, the *mutual information* (MI) between the traffic representation X and the label Y (with C unique websites) is:

$$I(X;Y) = H(Y) - H(Y \mid X) \in [0, \log_2 C] \text{ bits}.$$

Unlike accuracy, $I(X;Y)$ also credits near misses: if a model consistently narrows the candidate set without identifying the exact page, I still increases. Thus, I measures how much uncertainty an optimal attacker could remove, independently of any specific classifier. Two well-established yet complementary MI estimators for WF are:
(a) WeFDE [31] estimates the mutual information using manually selected features and kernel density estimators (KDE). WeFDE maps each trace to a vector of handcrafted features $\phi(x)$ (the same features as for k-FP — IAT, packet, burst statistics, CUMUL), then estimates class-conditional and marginal densities with kernel density estimation (KDE) on low-dimensional feature groups. Plugging those into the MI identity yields:

$$\widehat{I}_{\text{WeFDE}} \approx \frac{1}{N}\sum_{i=1}^{N} \log_2\!\left(\frac{\widehat{p}\big(\phi(x_i), y_i\big)}{\widehat{p}\big(\phi(x_i)\big)\,\widehat{p}(y_i)}\right),$$

where $\widehat{p}(\phi, y)$ and $\widehat{p}(\phi)$ are KDE estimates. Intuitively, the estimator approximates the relationship between the joint probability of observing a feature set ϕ together with a webpage label y ($\widehat{p}(\phi, y)$) and the product of their marginal probabilities $\widehat{p}(\phi)$ and $\widehat{p}(y)$. If the features are independent of the webpage, the joint probability equals the product of the marginal probabilities, yielding $\log_2(1) = 0$. Otherwise, dependence between the features and the webpage yields a nonzero value, indicating higher dependence between the features and the labels. This produces a total MI estimate in bits and per-feature/group leakage, pinpointing what still leaks.
(b) DeepSE-WF [67] leverages deep learning-derived latent spaces combined with specialized k-NN estimators to approximate MI.

While WeFDE provides an interpretable method for measuring information leakage directly from raw data, its accuracy depends heavily on the quality of the selected input features, and poor choices can create a false sense of security. To better approximate information leakage, the framework trains a deep neural network to project website traces into a continuous latent representation $Z = f(X)$. It then estimates $I(Z;Y)$ using a k-NN-based estimator [54], which is specifically designed for mixtures of discrete labels (Y) and continuous features (Z):

$$\hat{I}(Z;Y) = \psi(N) - \frac{1}{N}\sum_{i=1}^{N}\psi(n_i) + \psi(k) - \frac{1}{N}\sum_{i=1}^{N}\psi(m_i),$$

where ψ is the digamma function, N is the total number of samples, n_i is the number of samples sharing the class label of sample i, k is a hyperparameter (set to 5 in this work), and m_i is the number of points *regardless of class* lying within distance ε_i of x_i, where ε_i is the distance from x_i to its k-th nearest *same-class* neighbor. Finally, $\widehat{I}_{\text{DeepSE}} = \max_f \hat{I}(f(X);Y)$. This geometric approach allows dimensionality-dependent parameters to cancel out, making the estimator more robust in high-dimensional latent spaces. However, by the data processing inequality [15], $I(Z;Y) \leq I(X;Y)$, so $\hat{I}(Z;Y)$ is a *lower bound* on the true leakage — meaning the actual information available to an adversary may be larger, and any privacy guarantee implied by $\hat{I}(Z;Y)$ is therefore optimistic.

Interpreting the uncertainty estimators. To make the privacy implications more interpretable, we express conditional entropy as an effective number of plausible webpage labels, $2^{H(Y|X)}$. Larger values indicate greater residual uncertainty. Since the true mutual information $I(X;Y)$ is unknown, we use the larger of the two estimated leakage values as a proxy and derive the estimator-based uncertainty measure $\mathcal{K}^*$:

$$\mathcal{K}^* = 2^{H(Y) - \max\{\widehat{I}_{\text{WeFDE}},\, \widehat{I}_{\text{DeepSE}}\}}.$$

Here, $\max\{\widehat{I}_{\text{WeFDE}}, \widehat{I}_{\text{DeepSE}}\}$ is used as a proxy for the unknown $I(X;Y)$; consequently, $\mathcal{K}^*$ is an estimator-derived quantity rather than a bound on the true $2^{H(Y|X)}$. If the estimators underestimate the true leakage, the true effective candidate-set size may be smaller than the reported $\mathcal{K}^*$. The mutual-information estimates and the derived $\mathcal{K}^*$ values are reported as point estimates, as the employed estimators do not provide confidence intervals.

BBQ 4 **Defense Operational Cost:** *What is the added latency and traffic volume by the defense?*

For a webpage $y \in \mathcal{Y}$ under defense d, let $\text{Up}_d(y)$ denote the total upload bytes (client → server), $\text{Down}_d(y)$ the total download bytes (server → client), and $T_d(y)$ the duration until the last real content packet. Baseline values without defense are $\text{Up}_b(y)$, $\text{Down}_b(y)$, and $T_b(y)$. To quantify overheads, we compute the relative per-page increase ratio:

$$\Delta M(y) = \frac{M_d(y) - M_b(y)}{M_b(y)}, \quad M \in \{\text{Up}, \text{Down}, T\}.$$

Similar to prior work [63], (1) we report the median (Q2) and the first and third quantiles (Q1–Q3) of ΔM across all pages, pooled across all case studies; and (2) the latency overhead excludes trailing defensive traffic after the last real content packet, as this does not affect the user's perceived page load time.

Takeaways. All experiments in the following section use identical preprocessing and evaluation steps, ensuring that score differences arise solely from the traffic itself. Guided by our blueprint, we can:

- Calibrate each defense per dataset to identify a practical privacy–overhead operating point (BBQ 0);
- Detect when a dataset is easy to fingerprint (BBQ 1) or is trivial to get close to the real answer (BBQ 2);
- Identify cases where current ML models underperform, compared to the actual data leakage (BBQ 3);
- Compare manual-feature learning against deep-learning, keeping the stronger attacker in each case (BBQ 1–2: k-FP vs. VarCNN; BBQ 3: WeFDE vs. DeepSE);
- Uncover design flaws (or bugs) that inflate overhead, that falsely appear beneficial (BBQ 4).

5 Modelling WF Defenses in HTTP/2

We now discuss how to model existing fingerprinting defenses using HTTP/2. We first review established defensive techniques (Section 5.1). We then highlight HTTP/2 features and how they can enable defenses (Section 5.2). We finally tie these threads of knowledge by emulating HTTP/2 application-layer defenses for clients (Section 5.3) and for servers (Section 5.4).

5.1 Fingerprinting Defenses

WF defenses aim to disrupt site-specific bandwidth and latency patterns, using either *uniformity* (making all page loads appear identical) or *unpredictability* (making each page visit look random).

5.1.1 ***Fingerprinting Defenses Categories.*** Defenses can be broadly grouped into four categories: (1) *Noise traffic techniques* add dummy packets to obscure bandwidth patterns, often effective but costly in bandwidth [1, 23, 27, 29, 49, 63]; (2) *Padding techniques* (either through traffic morphing or adversarial perturbations) modify packet sizes to mimic other traffic patterns, usually with lower bandwidth overhead than pure noise injection, but often leaving timing patterns intact [3, 44, 50, 56, 71]. (3) *Traffic splitting techniques*, which alter the number of requests and responses [23, 29, 38, 63]; and (4) *Traffic-shaping techniques* enforce fixed-size packets at fixed intervals, achieving strong uniformity guarantees but at the cost of higher latency and bandwidth [6, 7, 20, 27, 37, 55].

5.1.2 ***Fingerprinting Defenses: Tor vs. Plain HTTPS.*** Most fingerprinting defense research focuses on Tor traffic [6, 7, 20, 23, 29, 37, 55, 69], where all data is multiplexed into fixed-size cells within a single tunnel. Plain HTTPS defenses instead complement Tor/VPN solutions: they do not hide the destination domain, but aim to reduce subpage leakage. This setting introduces additional challenges compared to the Tor/VPN defenses: packet sizes vary, and a page load spans multiple parallel TCP connections that can be fingerprinted independently. Some defenses are designed specifically for HTTPS [11], while others originally built for Tor can, in principle, be adapted [6, 23]. However, (1) traffic-shaping defenses must also address packet-size leakage and (2) unlike Tor, noise added to one connection does not propagate to the encapsulating layer — every leaking connection must be defended individually.

Defenses can be deployed at different points in the communication path: (1) Client-side (in the browser, OS, or client application),

Table 2: Comparison between the HTTP versions.

Feature	HTTP/1.1	HTTP/2	HTTP/3
Request Resource	✔	✔	✔
Range Requests	✔	✔	✔
Transport	TCP	TCP	UDP
Flow Control	×	✔	✔
Concurrent Streams	×	✔	✔
Stream Prioritization	×	✔	✔
Header Compression	×	✔	✔
Server-Push	×	(✔)	×
103 Early Hints	✔	✔	✔
Built-in Padding	×	Limited ≤ 255 B	Unlimited
Connection Probing	×	PING (8 B)	PING (no payload)

where traffic can be perturbed before it leaves the user's device [3, 6, 11, 23, 29, 38, 63]; or (2) Server-side (at the web server or CDN), where content delivery patterns, resource sizes, or response delays can be modified [1, 11]. In the following sections, we focus on one-sided (client-only or server-only) HTTP/2 application-layer defenses powered by unpredictability.

5.2 HTTP/2 Privacy Potential

HTTP/2 represents roughly 60% of browser traffic [4] and introduces several features beyond HTTP/1.1 that can be relevant to fingerprinting defenses. Table 2 outlines the key similarities and differences across HTTP versions.

As defined in RFC 9113 [65], the basic unit of the HTTP/2 communication is a *frame*. A *stream* is a bidirectional sequence of frames between the client and the server, mapped to a single client request. An HTTP/2 *connection* corresponds to a single TCP connection and comprises multiple streams, i.e., each carrying one or more requests and responses exchanged with the same server/subdomain.

5.2.1 **HTTP/1.1 *Inheritance*.** HTTP/2 inherits HTTP/1.1's header semantics — the same fields for method, path, status, and content negotiation. It also inherits Range requests (RFC 7233 [21]), which allow clients to fetch specific byte ranges of a resource, enabling application-layer traffic splitting.

5.2.2 **HTTP/2 *Multiplexing*.** On the transport side, HTTP/2 replaces HTTP/1.1 pipelining with stream multiplexing: multiple requests and responses are interleaved concurrently over a single persistent TCP connection without ordering constraints, eliminating head-of-line blocking. Beyond performance gains [2], multiplexing blurs the boundaries between individual encrypted requests and responses, with direct implications for connection privacy.

5.2.3 **HTTP/2 *Stream Prioritization*.** In HTTP/2, clients and servers can change the priority of streams depending on the content type (e.g., HTML, CSS, JS), the content location in the pages (above or below the visible fold), or from developer hints [47]. Stream reprioritization can also lead to unpredictable burst patterns, thus improving communication privacy.

5.2.4 **HTTP/2 *Flow Control*.** HTTP/2 introduces its own flow control at the application layer, independent of TCP's transport-layer flow control. While TCP flow control governs how much data can be in-flight on the network at once, HTTP/2 flow control operates per-stream: the receiver advertises an initial window size for each stream and can increment it via WINDOW_UPDATE frames, allowing it to pace or pause individual streams independently without affecting others on the same connection. This per-stream granularity has direct fingerprinting implications: by varying window sizes or deliberately delaying WINDOW_UPDATE frames, the receiver can alter the sizes and timing of downloaded DATA frames at the HTTP layer, independently of what TCP would otherwise permit.

5.2.5 **HTTP/2 *Resource Suggestions*.** HTTP/2 servers can proactively suggest or even deliver resources to the clients. One option is Server-Push frames, which let a server proactively send responses linked to a client's earlier request. For instance, after an HTML request, the server can push JavaScript, CSS, or images without waiting for additional requests. However, support for Server-Push has declined in recent years, with Chrome deprecating its support in 2022. Our evaluation of Server Push-based defenses serves primarily to establish theoretical bounds on server-side defense efficacy. A more widely adopted alternative is the HTTP '103 Early Hints' status code [45], which lets servers indicate critical resources for the client to fetch proactively. Unlike Server-Push, this approach gives the client full control over which resources to request, at the cost of an extra round trip.

5.2.6 **HTTP/2 *Built-in Padding*.** HTTP/2 offers limited support for padding for DATA, HEADERS, and PUSH_PROMISE frames, with up-to 255 bytes of extra noise. In contrast, QUIC provides dedicated PADDING frames [28], and HTTP/3 DATA frames can include arbitrary-length padding, making padding strategies more flexible than HTTP/2 's 255-byte limit per frame.

5.2.7 **HTTP/2 *Connection Probing.*** HTTP/2 uses PING frames for liveness checks and RTT measurements. Each PING frame must contain an 8-byte payload, which the remote party will echo.

5.2.8 **HTTP/2 *Opportunities for Fingerprinting Defenses*.** Unlike QUIC, which offers fine-grained stream-level flow control and lets applications dictate when and how packets are sent, HTTP/2 relies on TCP, where the OS stack manages transmission. As a result, defenses that depend on strict fixed-rate packet flows can only be approximated in HTTP/2, since it lacks QUIC's frame-level control.

While HTTP/2 offers features that could enhance privacy, their defensive potential has not been systematically quantified. Prior studies generally found that website fingerprinting remains effective against HTTP/2 traffic [22, 32, 33, 39, 42, 42, 43, 70], but did not actively leverage HTTP/2-specific mechanisms to strengthen communication privacy. To that end, in addition to emulating established defenses with HTTP/2, we are also interested in exploring the privacy impact of the aforementioned HTTP/2 features.

5.3 HTTP/2 Client-Side Defenses

We now show how HTTP/2 clients can increase privacy in the five case studies from Section 3.2. To that end, we emulate and evaluate four defensive strategies using HTTP/2 features: (1) HTTPOS [38], a traffic splitting technique; (2) LLaMA [11], a traffic morphing defense; (3) FRONT [23], a noise insertion strategy; and (4) Tamaraw [7], a traffic-shaping defense emulated from the *client-side*. The

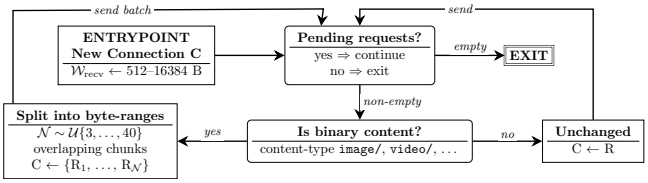


Figure 2: HTTP/2 emulation of the HTTPOS Defense [38].

following describes how each defense is adapted to HTTP/2 and includes a state machine diagram showing its page-load behavior.

5.3.1 ***HTTPOS.*** HTTPOS [38] obscures traffic patterns by splitting requests using the Range header to fetch specific or overlapping parts of binary resources (e.g., images), and by constraining the receive window so that responses arrive in smaller units. The original defense manipulates the TCP advertised window; we approximate this behavior using HTTP/2 flow control, which constrains DATA delivery while leaving the frame-to-segment mapping to the kernel. Request splitting changes the number of transmitted units, while overlapping ranges change how many bytes are transferred.

Yet, with this approach, the Range header is mainly applicable to binary data, and servers may ignore it altogether — e.g., by returning the full image even if only a byte range is requested. In our experiments, we assume the server cooperates. Figure 2 shows the HTTP/2 version of the defense.

For the HTTPOS defense calibration (**BBQ 0**), we jointly vary the initial HTTP/2 flow-control window $\mathcal{W}$ and the lower and upper limits $[S_{\min}, S_{\max}]$ of the range-split count $\mathcal{N}$, with $\mathcal{N} \sim \mathcal{U}\{S_{\min}, \ldots, S_{\max}\}$, across six candidate configurations spanning $\mathcal{W} = 16384$–512 B and range-split bounds from $[3, 5]$ to $[20, 40]$. Compared to the original implementation, we additionally vary the initial flow-control window. The six candidate configurations use $\mathcal{W} \in \{16384, 8192, 4096, 2048, 1024, 512\}$ B with corresponding range-split bounds $[S_{\min}, S_{\max}] \in \{[3, 5], [4, 7], [5, 8], [5, 10], [10, 20], [20, 40]\}$. Figure 3 shows that HTTPOS provides limited protection across the calibration sweep. On Amazon, increasing the defense intensity reduces the calibration Macro-F1 to 0.699 for $\mathcal{W} = 1024$ B and $\mathcal{N} \sim \mathcal{U}\{10, \ldots, 20\}$. On BBC and Reddit, the calibration Macro-F1 remains above 0.97 under the same configuration, and on Udemy and Wikipedia it remains above 0.97 even with $\mathcal{W} = 512$ B and $\mathcal{N} \sim \mathcal{U}\{20, \ldots, 40\}$. These results indicate that more aggressive range splitting alone does not substantially suppress fingerprinting leakage on most datasets. Following calibration, we therefore retain $\mathcal{W} = 1024$ B with $\mathcal{N} \sim \mathcal{U}\{10, \ldots, 20\}$ for Amazon, BBC, and Reddit, and $\mathcal{W} = 512$ B with $\mathcal{N} \sim \mathcal{U}\{20, \ldots, 40\}$ for Udemy and Wikipedia.

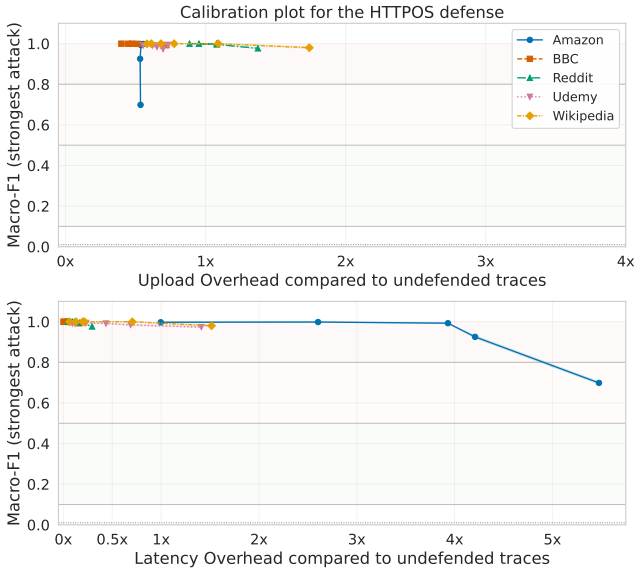


Figure 3: Calibration for the HTTPOS defense (BBQ 0). Strongest-attacker Macro-F1 per dataset against bandwidth (top) and latency (bottom) overhead. Horizontal lines mark the weak, moderate, and strong attacker thresholds; the dotted line is random guessing.

5.3.2 ***LLaMA.*** LLaMA [11] is an application-layer defense that obfuscates traffic by randomizing request order, using HTTP pipelining, introducing random delays, and injecting dummy traffic. In HTTP/2, request pipelining is natively supported through stream multiplexing. Each stream can be delayed independently without stalling the entire connection. LLaMA can leverage these features by grouping requests into random batches (up to 5 in our implementation) and reordering them before sending. Every request is delayed by $\mathcal{T} \sim \mathcal{U}(0, \tau)$; the original draws τ as half the median page load time, which assumes concurrent dispatch, so we scale it by the mean number of requests per page to obtain the same latency budget under sequential replay. To further increase ambiguity, LLaMA probabilistically issues dummy HTTP requests after each real request and received response, injecting noise into the traffic pattern. Figure 4 illustrates the HTTP/2 version of the defense.

For the LLaMA defense calibration (**BBQ 0**), we vary the dummy-request probability over $p_d \in \{0, 0.15, 0.25, 0.30, 0.50, 0.80\}$ while keeping the dataset-specific delay bound τ fixed. Figure 5 shows that LLaMA generally benefits from increasing the dummy-request probability, but the magnitude of the improvement is strongly dataset-dependent. On Amazon, the calibration Macro-F1 decreases to 0.296 at $p_d = 0.8$, while on BBC, Reddit, and Udemy the same configuration reaches 0.931, 0.691, and 0.756, respectively. On Wikipedia, $p_d = 0.5$ already reaches 0.784, while increasing p_d to 0.8 improves

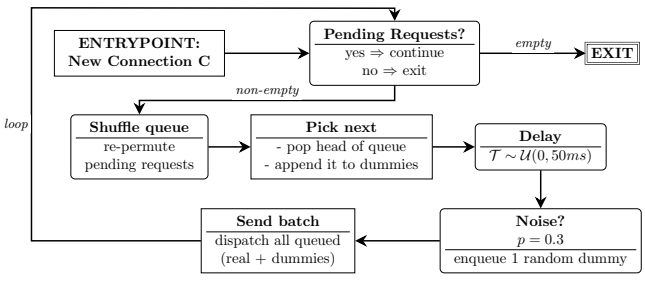


Figure 4: HTTP/2 emulation of the LLaMA Defense [11].

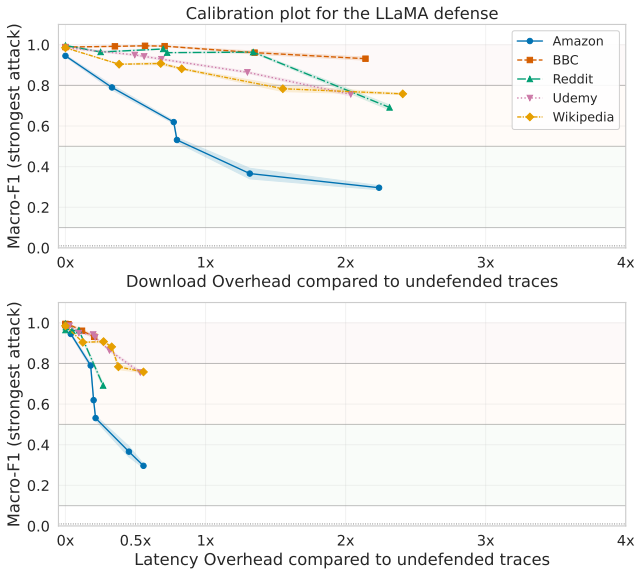


Figure 5: Calibration for the LLaMA defense (BBQ 0). Strongest-attacker Macro-F1 per dataset against bandwidth (top) and latency (bottom) overhead. Horizontal lines mark the weak, moderate, and strong attacker thresholds; the dotted line is random guessing.

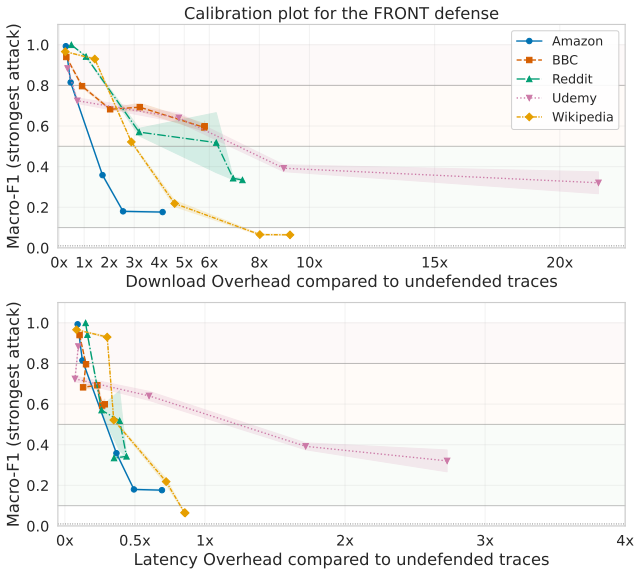


Figure 7: Calibration for the FRONT defense (BBQ 0). Strongest-attacker Macro-F1 per dataset against bandwidth (top) and latency (bottom) overhead. Horizontal lines mark the weak, moderate, and strong attacker thresholds; the dotted line is random guessing.

calibration Macro-F1 only to 0.758 while increasing both bandwidth and latency overhead.

The calibration shows that LLaMA generally benefits from increasing the dummy-request probability, but the magnitude of the improvement is strongly dataset-dependent. Consequently, we select $p_d = 0.8$ for Amazon, BBC, Reddit, and Udemy, and $p_d = 0.5$ for Wikipedia.

5.3.3 ***FRONT.*** The FRONT defense [23] injects N dummy packets at timestamps drawn from a Rayleigh($\mathcal{W}$) distribution, where the scale $\mathcal{W} \sim \mathcal{U}(0, 1)$ is randomized per connection. In our HTTP/2 adaptation, for each connection c, we sample the number of scheduled dummy transmissions as $N_c \sim \mathcal{U}\{1, \ldots, N_{\max}\}$, independently sample $\mathcal{W}_c \sim \mathcal{U}(0, 1)$ seconds, and draw N_c transmission times from Rayleigh($\mathcal{W}_c$). Thus, both the dummy volume and timing pattern vary across connections. QCSD [63] adapted FRONT to

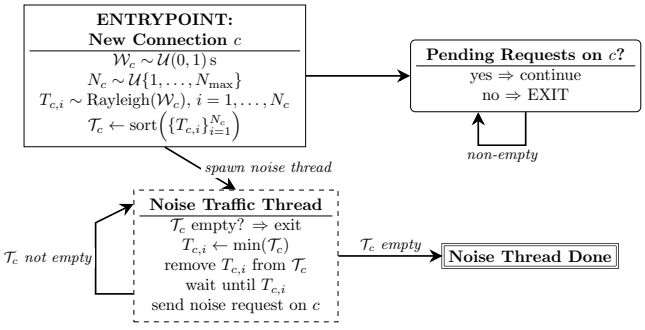


Figure 6: HTTP/2 emulation of the FRONT defense [23].

QUIC, and the same noise-scheduling principles apply to HTTP/2. Figure 6 summarizes our HTTP/2 emulation and its parameters.

For the FRONT defense calibration (**BBQ 0**), we vary the maximum per-connection dummy-stream budget $N_{\max} \in \{20, 50, 110, 200, 350, 500\}$. Figure 7 shows a clear privacy–overhead knee on all five datasets. On Amazon, the calibration Macro-F1 decreases from 0.358 at $N_{\max} = 110$ to 0.180 at $N_{\max} = 200$, whereas increasing the budget to 350 provides almost no further improvement (0.176) while substantially increasing bandwidth overhead. Similarly, Reddit improves from 0.518 at $N_{\max} = 200$ to 0.343 at $N_{\max} = 350$, while increasing the budget to 500 reaches only 0.334; Wikipedia reaches 0.065 at $N_{\max} = 350$ and 0.064 at $N_{\max} = 500$. On BBC, $N_{\max} = 350$ achieves the lowest observed Macro-F1 (0.593), with no benefit from increasing the budget to 500. On Udemy, increasing $N_{\max}$ from 200 to 350 improves the calibration Macro-F1 from 0.392 to 0.320, but increases downstream and upstream overhead from 8.97 and 7.16 to 21.55 and 16.21, respectively; we therefore retain the lower-overhead configuration.

The calibration shows that FRONT exhibits a clear privacy–overhead knee on all five datasets, with the selected operating points yielding a calibration Macro-F1 of at most 0.593. We therefore select $N_{\max} = 200$ for Amazon and Udemy, and $N_{\max} = 350$ for BBC, Reddit, and Wikipedia.

5.3.4 ***CL-Tamaraw.*** The Tamaraw defense [7] obfuscates traffic by enforcing fixed-size packets at a constant rate. While feasible in Tor entry nodes — where traffic can be modified bidirectionally — this makes Tamaraw difficult to adapt to HTTP/2. QCSD [63] showed that similar behavior can be reproduced in QUIC using flow control and multiplexing. HTTP/2 frame sizes are under application

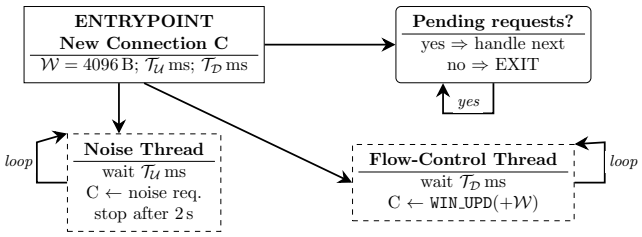


Figure 8: HTTP/2 emulation of the CL-Tamaraw Defense [7].

control, but the mapping of frames to TCP segments is governed by the kernel, so a fixed-rate fixed-size packet stream cannot be enforced from userspace; instead, we approximate constant-rate behavior through flow-control window updates — i.e., the client can request a small initial flow-control window, thereby limiting the size of DATA frames the server can send. After receiving a fixed amount of data, the client can intentionally delay sending window update frames — pausing the server's transmission — to mimic fixed-rate response defenses. Due to the TCP flow control in the kernel, this does not achieve a perfectly constant rate; yet, it still alters the observable timing patterns of the response. In addition, the defense issues noise requests at a fixed rate, further disrupting burst and cumulative statistics. Figure 8 outlines our client-side emulation of Tamaraw using HTTP/2, noting that it is not a full replication of the original Tor defense.

For the CL-Tamaraw defense calibration (**BBQ 0**), we vary only the dummy-request interval $\mathcal{T}_U \in \{320, 80, 40, 20, 10, 5\}$ ms, while

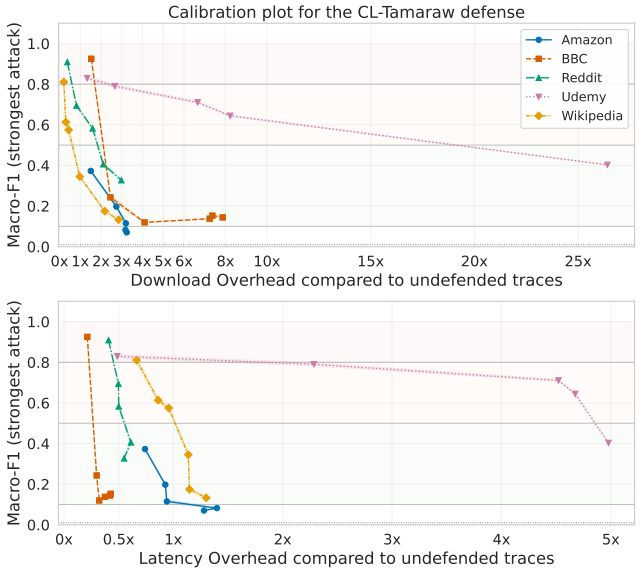


Figure 9: Calibration for the CL-Tamaraw defense (BBQ 0). Strongest-attacker Macro-F1 per dataset against bandwidth (top) and latency (bottom) overhead. Horizontal lines mark the weak, moderate, and strong attacker thresholds; the dotted line is random guessing.

holding the flow-control window at $\mathcal{W}$ = 4096 B and the receive-delay bound $\mathcal{T}_D$ at 10 ms. The receive-delay threshold is fixed to 4096 B. Figure 9 shows that CL-Tamaraw exhibits strong dataset dependence and early saturation on several datasets. On Amazon, the calibration Macro-F1 reaches 0.082 at $\mathcal{T}_U$ = 20 ms and improves only to 0.070 at 10 ms, so we select 20 ms. On BBC, $\mathcal{T}_U$ = 40 ms already achieves the lowest observed Macro-F1 (0.120); shorter intervals increase overhead without improving protection, so 40 ms is selected. Reddit continues to benefit from stronger shaping throughout the evaluated range, reaching 0.327 at $\mathcal{T}_U$ = 5 ms, which is therefore selected. Udemy presents a substantially less favorable trade-off: reducing $\mathcal{T}_U$ from 20 ms to 5 ms reduces the calibration Macro-F1 from 0.644 to 0.403, but increases downstream overhead from 8.23 to 26.41 and upstream overhead from 10.47 to 28.29. We therefore retain 20 ms as the practical operating point. Finally, Wikipedia reaches 0.175 at $\mathcal{T}_U$ = 10 ms, while 5 ms provides only a modest additional reduction to 0.133; we select 10 ms.

Using a calibration target of strongest-attacker Macro-F1 closest below 0.5, while avoiding unnecessarily costly configurations, we select $\mathcal{T}_U$ = 20 ms for Amazon and Udemy, 40 ms for BBC, 5 ms for Reddit, and 10 ms for Wikipedia.

5.3.5 ***Fingerprinting on Client-Defended Datasets.*** Table 3 summarizes the Macro-F1, Top-5 and $\mathcal{K}^*$ scores for each dataset under calibrated client-side defenses, using the strongest attacker for each dataset–defense pair, with attackers hyperparameter-tuned independently for each pair (**BBQ 1 – 3**). CL-Tamaraw provides the strongest resilience across all five datasets.

We first look at the Macro-F1 score. FRONT provides the second strongest protection overall, with its best results on Amazon (0.54) and Wikipedia (0.43), but remains much less effective on BBC, Reddit, and Udemy (0.89, 0.88, and 0.89, respectively). CL-Tamaraw achieves the lowest Macro-F1 on every dataset, reaching 0.24 on Amazon and BBC, 0.38 on Reddit, and 0.42 on Wikipedia, but remains weak on Udemy (0.88). In contrast, HTTPOS is largely ineffective across all five datasets, with Macro-F1 ranging from 0.86 to 0.99. LLaMA similarly fails to provide meaningful protection, with Macro-F1 remaining above 0.80 for all datasets. From the attacker's perspective, RobustFP-CNN and Holmes shine against heavier defenses (FRONT, CL-Tamaraw, LLaMA), while k-FP dominates against lighter defenses (HTTPOS). One explanation is that defended traces are longer (noise packets extend the sequence), giving the CNN models more context windows to find stable patterns that survive noise injection.

The Top-5 results further distinguish defenses that merely disrupt the attacker's top-ranked prediction from those that induce broader ranking uncertainty. With CL-Tamaraw, Top-5 accuracy falls to under 0.55 on Amazon, BBC, and Reddit, respectively, indicating that the true webpage is absent from even the attacker's five highest-ranked candidates in roughly half of the traces. Wikipedia shows a similar, though weaker, effect (0.62). In contrast, Udemy remains highly identifiable under every defense: even with CL-Tamaraw, Top-5 accuracy is 0.99. FRONT exhibits meaningful Top-5 robustness primarily on Wikipedia (0.70), while its Top-5 accuracy remains at least 0.87 on the other datasets.

Table 3: Baseline resilience of the HTTP/2 *Client Defenses* against the best-performing evaluated attacker (BBQ 1 and 2), together with the estimator-derived anonymity-set proxy $\mathcal{K}^*$ (BBQ 3). Macro-F1 and Top-5 are means; their 95% CIs are below 0.02 and omitted.

Dataset	Metric	HTTPOS	LLaMA	FRONT	CL-TAM
Amazon	Macro-F1	0.86	0.82	0.54	**0.24**
	Top-5	0.96	0.96	0.87	**0.51**
	$\mathcal{K}^*$	2.84	3.62	16.80	**38.43**
BBC	Macro-F1	0.99	0.99	0.89	**0.24**
	Top-5	1.00	1.00	0.95	**0.54**
	$\mathcal{K}^*$	1.10	1.13	2.28	**26.64**
Reddit	Macro-F1	0.98	0.97	0.88	**0.38**
	Top-5	1.00	0.99	0.98	**0.47**
	$\mathcal{K}^*$	1.22	1.31	2.57	**34.08**
Udemy	Macro-F1	0.99	0.96	0.89	**0.88**
	Top-5	1.00	1.00	1.00	**0.99**
	$\mathcal{K}^*$	1.10	1.22	1.82	**2.48**
Wiki	Macro-F1	0.99	0.98	0.43	**0.42**
	Top-5	1.00	1.00	0.70	**0.62**
	$\mathcal{K}^*$	1.16	1.24	27.66	**27.89**

Table 3 further reports model-agnostic anonymity-set sizes $\mathcal{K}^*$ under client defenses (**BBQ 3**), capturing attacker uncertainty beyond Top-k metrics (higher $\mathcal{K}^*$ indicates greater uncertainty). The estimates show that CL-Tamaraw induces genuine ambiguity rather than merely perturbing the top-ranked guesses: on BBC, despite Top-5= 0.54, $\mathcal{K}^* = 26.64$, leaving a substantially broader set of plausible webpages. Across BBQ 1–3, CL-Tamaraw is the most robust defense, with FRONT competitive on Amazon and Wikipedia.

Finally, Table 4 summarizes the privacy–cost trade-offs of the client defenses (**BBQ 4**). HTTPOS adds little downstream traffic (ΔDown = 0.04) but increases upload and latency (ΔUp = 0.81, $\Delta T = 1.04$), while providing weak privacy. LLaMA has the lowest latency overhead ($\Delta T = 0.35$) but roughly doubles traffic in both directions and likewise provides limited protection. FRONT and CL-Tamaraw incur the largest bandwidth costs: FRONT reaches ΔDown = 5.76, while CL-Tamaraw reaches 3.73. However, FRONT shows a smaller impact on the perceived latency. Overall (BBQ 1–4), CL-Tamaraw provides the strongest client-side privacy but at substantial cost, while FRONT offers a lower-latency alternative on Amazon and Wikipedia. More broadly, the dataset-specific defense settings and strongest attackers vary across workloads, underscoring the need for multi-dataset evaluation even when defenses and attackers are individually tuned.

Table 4: Client-side defenses overhead: median (Q1–Q3) of the relative increase ratio ΔM. Baseline averages shown for reference (BBQ 4).

Defense	ΔUp	ΔDown	ΔT
HTTPOS	0.8 (0.6 – 1.4)	0.0 (0.0 – 0.1)	1.0 (0.3 – 2.1)
LLaMA	1.9 (1.7 – 2.6)	2.1 (1.7 – 2.4)	0.4 (0.2 – 0.5)
FRONT	7.4 (4.4 – 11.1)	5.8 (3.1 – 8.9)	0.5 (0.2 – 1.1)
CL-TAM	6.7 (2.8 – 11.6)	3.7 (1.9 – 8.4)	1.0 (0.5 – 3.0)
Baseline avg.	5.37 KB	2638.1 KB	2.97 s

Takeaways. We demonstrated practical emulations of popular client-side defenses using HTTP/2 primitives, highlighting both their strengths and limitations. Client-side defenses uniformly cover all connections within a page load, but cannot directly control download leakage and may incur substantial bandwidth and latency overhead. Their effectiveness is also strongly dataset-dependent, requiring defense parameters to be calibrated separately for each dataset rather than using a single operating point. Overall, CL-Tamaraw provides the strongest privacy, reaching $\mathcal{K}^* = 38.43$ on Amazon but dropping to $\mathcal{K}^* = 2.48$ on Udemy, at median overheads of ΔDown = 3.7 and $\Delta T = 1.0$; FRONT provides a lower-latency alternative on Amazon and Wikipedia, with a median $\Delta T = 0.5$ but similarly substantial bandwidth overhead.

5.4 HTTP/2 Server-Side Defenses

In this section, we benchmark established defenses from the perspective of the HTTP/2 server. The server-side defenses follow the same principles as the client-side defenses: they must be able to pad, split, delay, or add additional noise. We adopt two known fingerprinting defenses, which *can be emulated at the application layer* (1) ALPaCA [11], a web object morphing strategy; and (2) Tamaraw [7], emulated from the server perspective.

At first glance, server-side defenses seem attractive since they could, in principle, protect all users. In practice, however, modern webpages are rarely monolithic. As shown in Table 1 and prior work [61], most page loads span multiple servers. Unlike clients, which observe and can defend all connections uniformly, servers act independently — and many may not deploy any protection.

In our benchmarks, we therefore assume no shared proxy or centralized cloud deployment: each subdomain involved in the webpage load applies defenses individually, while clients follow proactive resource suggestions. The HTTP/2 adaptations deliver noise via Server Push frames as a proof-of-concept; while some browsers have dropped Server Push support [72], the mechanism can be replaced by 103 Early Hints — as demonstrated in Section 6.

5.4.1 ***ALPaCA***. The ALPaCA defense [11] supports two modes: a mimicking mode, which reshapes a site toward a larger reference site, and a noise mode, which perturbs resource sizes and injects additional resources. We evaluate the noise mode because it does not require selecting a reference website and maps directly to randomized padding and noise injection in our HTTP/2 setting. ALPaCA alters the webpage's actual content length (images, HTML, CSS, etc.) so that traffic patterns become indistinguishable and unpredictable to a passive adversary. The original design works by (1) padding each object (e.g., an image, CSS file, HTML) with random data and by (2) inserting noise traffic (fake resources) in the main HTML. Figure 10 illustrates the HTTP/2 adaptation of the defense. Here, object-size perturbation is emulated by injecting dummy bytes into HEADERS frames. Unlike the original ALPaCA, which embeds fake resource references in HTML, the HTTP/2 adaptation proactively

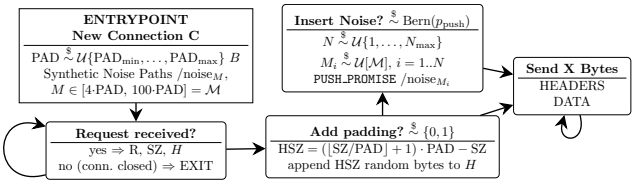


Figure 10: HTTP/2 ALPaCA Server-Side Defense [11].

delivers noisy resources via Server Push frames, without modifying HTML content.

For the ALPaCA defense calibration (**BBQ 0**), we jointly vary ALPaCA's per-connection padding range, maximum number of pushed noise objects, and push probability p_{push}. Calibration is performed with ALPaCA enabled on all connections involved in the page load. The three parameters scale together because each strengthens the same padding-and-noise mechanism, and noise-object sizes are defined relative to the padding granularity. The four candidate configurations use padding ranges $[256, 1024]$, $[512, 4000]$, $[768, 6000]$, and $[1024, 8000]$ B, with corresponding maximum numbers of noise objects 2, 4, 6, and 10, and $p_{\text{push}} \in \{0.2, 0.3, 0.4, 0.5\}$, respectively. Figure 11 shows that ALPaCA requires relatively aggressive padding before providing substantial protection. Increasing the padding range from $[768, 6000]$ B to $[1024, 8000]$ B, the maximum number of noise objects from 6 to 10, and p_{push} from 0.4 to 0.5 reduces the calibration Macro-F1 from 0.312 to 0.147 on Amazon, 0.401 to 0.068 on BBC, 0.229 to 0.027 on Reddit, 0.187 to 0.035 on Udemy, and 0.708 to 0.033 on Wikipedia. Although this increase also incurs substantial downstream and latency overhead, the additional privacy gain remains large on every dataset. The calibration shows a sharp transition: padding drawn from $[1024, 8000]$ B, with up to 10 noise objects and $p_{\text{push}} = 0.5$, reduces calibration Macro-F1 below 0.15 on every dataset, whereas the immediately weaker configuration remains between 0.19 and 0.71. We therefore select this defense configuration for all five datasets.

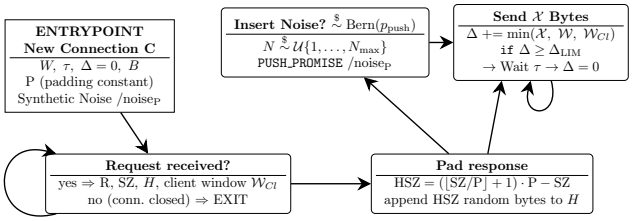


Figure 12: HTTP/2 emulation of the SRV-Tamaraw Defense [7].

5.4.2 ***SRV-Tamaraw (SRV-TAM).*** We emulate Tamaraw from the server side using three mechanisms: (1) noise injection via Server Push, (2) response padding to a fixed-size multiple, and (3) paced transmission. Unlike ALPaCA's randomized per-connection padding, SRV-Tamaraw uses a fixed padding size to enforce more uniform traffic shaping. The server tracks transmitted bytes with a counter Δ and pauses for τ whenever Δ reaches the threshold B, before resetting the counter. Figure 12 illustrates the HTTP/2 adaptation.

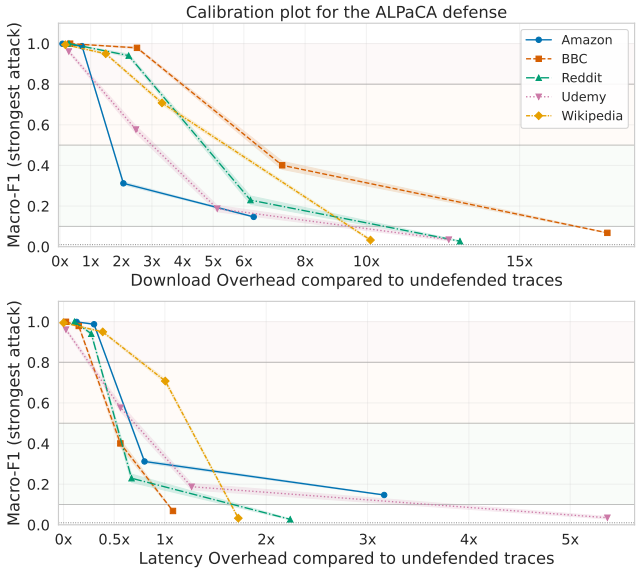


Figure 11: Calibration for the ALPaCA defense (BBQ 0). Strongest-attacker Macro-F1 per dataset against bandwidth (top) and latency (bottom) overhead. Horizontal lines mark the weak, moderate, and strong attacker thresholds; the dotted line is random guessing.

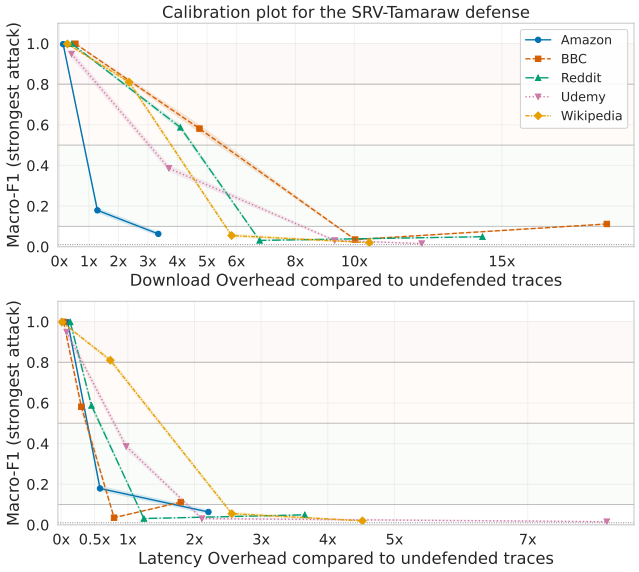


Figure 13: Calibration for the SRV-Tamaraw defense (BBQ 0). Strongest-attacker Macro-F1 per dataset against bandwidth (top) and latency (bottom) overhead. Horizontal lines mark the weak, moderate, and strong attacker thresholds; the dotted line is random guessing.

For the SRV-Tamaraw defense calibration (**BBQ 0**), we jointly vary the padding constant P, output flow-control window W, send delay τ, pacing threshold B, maximum number of pushed noise objects $N_{\max}$, and push probability p_{push}. These parameters scale together to increase shaping intensity through larger padding, tighter flow control, longer pauses, and more noise. The four candidate configurations use $(P, W, \tau, B, N_{\max}, p_{\text{push}})$ values $(1024, 16384, 0.2, 16384, 2, 0.2)$, $(4096, 8192, 0.5, 8192, 4, 0.3)$, $(6144, 4096, 0.8, 6144, 6, 0.4)$, and $(8092, 2048, 1.0, 4096, 10, 0.5)$, respectively, where P, W, and B are in bytes and τ is in milliseconds. Figure 13 shows a clear privacy–overhead knee at $P = 6144\,\text{B}$, $W = 4096\,\text{B}$, $\tau = 0.8\,\text{ms}$, $B = 6144\,\text{B}$, $N_{\max} = 6$, and $p_{\text{push}} = 0.4$. On Amazon, this configuration reaches a calibration Macro-F1 of 0.063. On BBC and Reddit, it reaches 0.035 and 0.031, respectively, and the stronger configuration does not improve protection. On Udemy, the stronger configuration reduces Macro-F1 only from 0.031 to 0.015, while latency overhead increases from 2.11 to 8.19. Similarly, on Wikipedia, it reduces Macro-F1 from 0.055 to 0.020 while downstream overhead increases from 5.84 to 10.51 and latency overhead from 2.56 to 4.52.

The calibration shows a clear knee at $P = 6144\,\text{B}$, $W = 4096\,\text{B}$, $\tau = 0.8\,\text{ms}$, $B = 6144\,\text{B}$, $N_{\max} = 6$, and $p_{\text{push}} = 0.4$, reducing calibration Macro-F1 to 0.031–0.063 across all five datasets. Stronger shaping provides limited additional protection at substantially higher overhead, so we select this configuration for all datasets.

5.4.3 ***Fingerprinting on Server-Defended Datasets.*** For each website, we benchmark the defenses applied to either the main page connection (1st Party), the leakiest third-party server (CDN), or all servers involved (All).

Table 5 reports the privacy of the calibrated server-side defenses against the strongest hyperparameter-tuned attacker for each dataset–defense pair (**BBQ 1** and **BBQ 2**). Placement remains the dominant factor. On Amazon, defending the CDN connection is already highly effective for SRV-TAM (F1 = 0.26, $\mathcal{K}^* = 24.47$), whereas defending only the first-party server provides essentially no protection. BBC shows the opposite extreme: neither single-server placement is sufficient, but deployment across all servers reduces F1 to 0.20 for ALPaCA and 0.15 for SRV-TAM. Reddit, Udemy, and Wikipedia exhibit stronger first-party leakage: ALPaCA reaches F1 = 0.33 and 0.09 on Reddit and Wikipedia, respectively, while SRV-TAM reaches 0.41 on Udemy.

The anonymity-set estimates (**BBQ 3**) reinforce this placement effect. Targeting a single dominant connection can already provide substantial ambiguity—for example, $\mathcal{K}^* = 24.47$ for SRV-TAM on Amazon's CDN, 39.31 for ALPaCA on Reddit's first-party server, and 76.26 for ALPaCA on Wikipedia's first-party server. When leakage is distributed across connections, however, full deployment is necessary: on BBC, $\mathcal{K}^*$ rises from at most 2.32 under any single-server placement to 23.56 with ALPaCA-All and 63.08 with SRV-TAM-All. Full deployment is also particularly effective on Udemy, where SRV-TAM reaches F1 = 0.03 and $\mathcal{K}^* = 97.51$. Overall, the results show that server-side defenses can provide strong privacy, but their effectiveness depends critically on placing the defense at the connections carrying the dominant fingerprinting signal rather than simply instrumenting the first-party server.

Table 6 reports the overhead of the calibrated server-side defenses (**BBQ 4**). Both defenses incur zero upload overhead because the client sends no additional requests. Because each defense is calibrated per dataset toward its strongest practical privacy operating point, the reported overhead also reflects the cost of the selected protection level rather than a matched-cost comparison. In these conditions, SRV-TAM is nevertheless consistently cheaper than ALPaCA. Thus, ALPaCA's higher overhead partly reflects the stronger configuration selected during calibration, while SRV-TAM provides the more favorable privacy–overhead trade-off overall.

Table 5: Baseline resilience of the HTTP/2 *Server Defenses* against the best-performing evaluated attacker (BBQ 1 and 2), together with the estimator-derived anonymity-set proxy $\mathcal{K}^*$ (BBQ 3). The best scores among single-server deployments are underlined, while the best-performing deployments overall are highlighted in bold. Macro-F1 and Top-5 are means; their 95% CIs are below 0.02 and omitted.

Data	Metric	ALPaCA			SRV-TAM		
		1st Party	CDN	All	1st Party	CDN	All
Amz.	F1	1.00	0.76	0.21	1.00	0.26	**0.08**
	Top-5	1.00	0.94	0.59	1.00	0.51	**0.30**
	$\mathcal{K}^*$	1.01	5.21	62.15	1.02	24.47	**77.10**
BBC	F1	0.99	0.87	0.20	0.94	0.90	**0.15**
	Top-5	1.00	0.99	0.54	0.96	0.98	**0.43**
	$\mathcal{K}^*$	1.06	2.32	23.56	1.62	1.70	**63.08**
Reddit	F1	0.33	0.97	**0.04**	0.76	0.98	0.06
	Top-5	0.45	1.00	**0.18**	0.92	1.00	0.22
	$\mathcal{K}^*$	39.31	1.37	**83.42**	5.23	1.23	82.19
Udemy	F1	0.64	0.49	0.08	0.41	0.83	**0.03**
	Top-5	0.91	0.85	0.27	0.54	0.99	**0.12**
	$\mathcal{K}^*$	8.14	9.46	57.93	14.55	3.43	**97.51**
Wiki	F1	0.09	0.97	**0.06**	0.69	0.97	0.08
	Top-5	**0.17**	1.00	0.20	0.93	0.99	0.25
	$\mathcal{K}^*$	**76.26**	1.36	65.72	7.83	1.34	74.92

5.4.4 ***Takeaways.*** We demonstrated practical emulations of established server-side defenses using HTTP/2 features, with defense parameters calibrated per dataset and attackers' hyperparameters

Table 6: Server-side defenses overhead ratio: median (Q1–Q3) of the relative increase ratio ΔM pooled across all five case studies, for single-server (top) and all-servers (bottom) deployments. (BBQ 4). ΔUp $= 0$ throughout, as the client sends no additional requests.

Defense		ΔDown	ΔT
ALPaCA	Single Srv.	4.9 (2.9 − 7.8)	0.7 (0.4 − 1.7)
	All Srv.	11.7 (7.1 − 15.8)	2.4 (1.4 − 4.2)
SRV-TAM	Single Srv.	3.6 (2.1 − 6.3)	0.5 (0.3 − 1.5)
	All Srv.	6.8 (4.4 − 9.6)	1.7 (1.0 − 2.6)
Baseline avg.		2638.10 KB	2.97 s

tuned independently for each dataset–defense pair. The results remain strongly dataset- and placement-dependent: the most effective single-server deployment varies across case studies, while protecting all participating servers generally provides the strongest privacy at higher cost. Overall, SRV-TAM provides the stronger privacy–overhead trade-off for full deployment, while targeted single-server defenses can be highly effective when one connection dominates the leakage (e.g., Amazon, Reddit, Udemy or Wikipedia).

6 The Untapped Potential of HTTP/2 for Fingerprinting Defenses

We showed that HTTP/2 users can emulate *established* WF defenses, achieving privacy improvements across all case studies and deployment perspectives (client and server). Yet, these guarantees often come at considerable overhead or depend on carefully targeting the right servers — limitations that stem from the fact that these defenses were never designed with HTTP/2 's architecture in mind.

6.1 Opportunities with HTTP/2

Can we do better? In this section, we outline various novel strategies for leveraging HTTP/2 features to raise the baseline privacy of page loads and to overcome key limitations of existing defense designs.

6.1.1 ***Client Side.*** Most defenses assume noise is essential, overlooking the privacy benefits inherent in application-layer behavior, such as multiplexing and flow control. We first detail HTTP/2's features, which can improve privacy from the client perspective, then discuss how to insert noise more efficiently.

Client Opportunity 1: Randomizing client behavior by using HTTP/2 features can improve the baseline privacy.

A light privacy-conscious HTTP/2 client (H2PC) can leverage the following features:

- *Multiplexing & Prioritization.* The client can shuffle and batch a subset of the pending requests, proactively altering the burst patterns of the connection.
- *Flow Control.* While the Tamaraw defense uses flow control for uniform traffic shaping, we can also turn it into an unpredictability-driven defense. Concretely, the client can randomize flow control window sizes per connection, enforcing different burst patterns on each page reload.
- *Connection Probing.* PING frames carry only 8 bytes, so they minimally affect bandwidth. As long as the mechanism is not abused, inserting a random number of PINGs disrupts burst patterns when combined with prior techniques.

Client Opportunity 2: HTTP/2 primitives allow clients to create 'guarding' noise streams.

A key lesson from existing defenses is that more noise generally yields stronger privacy. For example, if we vary the noise quantity ceiling in the FRONT defense for the Udemy dataset between $10 \rightarrow 500$, we get a monotonic F1 score variation between $[0.48 - 0.76]$. Yet, the critical question of "how much noise is enough" remains largely unaddressed. To move beyond brute-force noise, we leverage

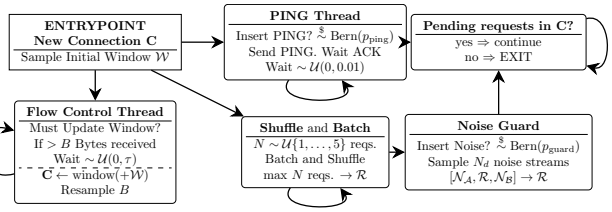


Figure 14: A privacy-conscious HTTP/2 client (H2PC) flow.

HTTP/2 features against primary leakage sources, yielding more efficient and scalable defenses.

A notable idea comes from the HTTPOS [38] defense, which focuses on binary resources — often the leakiest. Its strategy can be generalized: large resources can be guarded by surrounding them with noise streams, allowing HTTP/2 to multiplex guarding streams alongside legitimate traffic, with the frame scheduler interleaving DATA frames from multiple streams in a pattern that depends on window sizes, priorities, and implementation-specific scheduling. Unlike HTTPOS, this approach is not limited to binary content and does not require server cooperation. And unlike LLaMA, FRONT, or CL-Tamaraw, it targets the sensitive streams directly rather than relying on opportunistic overlaps between noise and real traffic.

Figure 14 depicts the client-side defense workflow. For each connection **C**, the client (i) randomizes the initial receive window $\mathcal{W}$ using the flow-control parameters and (ii) launches an independent PING thread whose frames, when serialized into TCP segments, probabilistically interleave with DATA-frame segments, perturbing observable burst-direction patterns. Pending requests are then grouped into randomized batches and reordered (as in LLaMA), while each request may be accompanied by sampled guarding noise, altering CUMUL and packet-level statistics. After receiving B bytes, the client introduces additional randomness by delaying the receive-window update by a value sampled from $\mathcal{U}(0, \tau)$ and resampling B, further obscuring timing patterns. Resampling prevents window updates from occurring at deterministic byte intervals, which could otherwise become a learnable signature.

For defense calibration (**BBQ 0**), we calibrate five parameters: the guarding-stream limit N_d, PING probability p_{ping} and count range, receive-delay bound τ, and receive-delay threshold B. The two weakest configurations use no guarding streams, isolating the effect of HTTP/2-native randomization before guarding noise is introduced: the first uses randomized flow control alone, while the second adds PING padding, both with negligible measured bandwidth overhead.

The six candidate configurations progressively increase the guarding-stream and PING activity while tightening the receive-delay parameters. The first uses $N_d = 0$, $p_{\text{ping}} = 0$, PING count $[1, 1]$, $\tau = 50\,\mu$s, and $B = 20000$ B; the second uses $N_d = 0$ $p_{\text{ping}} = 0.25$, PING count $[1, 2]$, $\tau = 50\,\mu$s, and $B = 20000$ B; and the third uses $N_d = 1$, $p_{\text{ping}} = 0.35$, PING count $[1, 2]$, $\tau = 80\,\mu$s, and $B = 15000$ B. The remaining configurations use $(N_d, p_{\text{ping}}) = (1, 0.50)$, $(2, 0.70)$, and $(3, 1.00)$, with PING-count ranges $[1, 3]$, $[1, 5]$, and $[2, 8]$, receive-delay bounds of 100, 200, and 500 μs, and thresholds of 10000, 5000, and 2500 B, respectively. Figure 15 shows a comparatively consistent reduction in attacker performance as H2PC intensity increases.

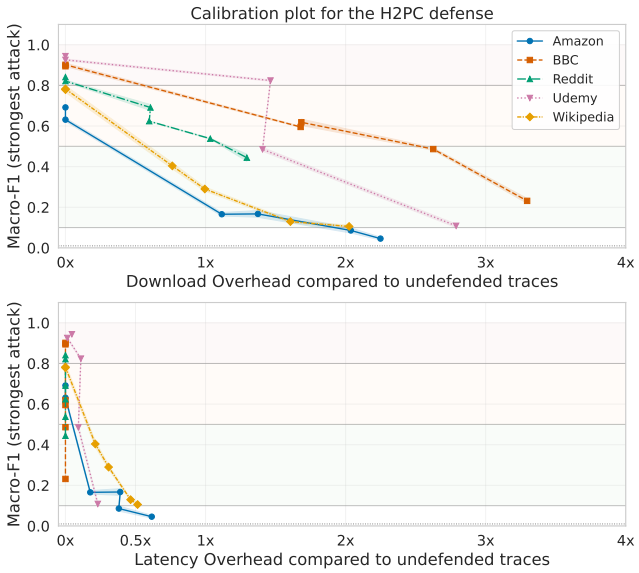


Figure 15: Calibration for the H2PC defense (BBQ 0). Strongest-attacker Macro-F1 per dataset against bandwidth (top) and latency (bottom) overhead. Horizontal lines mark the weak, moderate, and strong attacker thresholds; the dotted line is random guessing.

On Amazon, the calibration Macro-F1 decreases from 0.167 with $N_d = 1$, $p_{\text{ping}} = 0.5$, $\tau = 100\,\mu$s, and $B = 10000$ B to 0.086 with $N_d = 2$, $p_{\text{ping}} = 0.7$, $\tau = 200\,\mu$s, and $B = 5000$ B; the strongest configuration further reduces it to 0.046, but with additional bandwidth and latency overhead. Wikipedia shows a similar knee, decreasing from 0.290 to 0.130 and then 0.105 across the same configurations. In contrast, BBC, Reddit, and Udemy continue to obtain substantial privacy gains at the strongest configuration, reaching Macro-F1 values of 0.232, 0.444, and 0.109, respectively.

Calibration reveals two operating regimes: Amazon and Wikipedia favor an intermediate privacy–overhead point, whereas BBC, Reddit, and Udemy justify the strongest configuration. For Amazon and Wikipedia, we select $N_d = 2$, $p_{\text{ping}} = 0.7$, PING count $[1, 5]$, $\tau = 200\,\mu$s, and $B = 5000$ B, reaching calibration Macro-F1 ≤ 0.13. For BBC, Reddit, and Udemy, we select the strongest configuration, $N_d = 3$, $p_{\text{ping}} = 1.0$, PING count $[2, 8]$, $\tau = 500\,\mu$s, and $B = 2500$ B, reaching calibration Macro-F1 ≤ 0.44.

Table 7 compares H2PC against CL-Tamaraw, the strongest client-side defense overall, across privacy and overhead (**BBQ 1–4**). H2PC keeps attacker Macro-F1 at or below 0.70 on all five datasets while substantially reducing latency and downstream overhead. On Amazon, BBC, Reddit, and Wikipedia, this yields a lower-cost privacy operating point: H2PC maintains $\mathcal{K}^* \geq 7.32$ while reducing ΔT and ΔDown relative to CL-Tamaraw. The trade-off is especially favorable on Udemy, where H2PC improves $\mathcal{K}^*$ from 2.48 to 7.31, while reducing ΔT from 4.7 to 0.2 and ΔDown from 8.2 to 2.8. Overall, H2PC provides competitive privacy at substantially lower cost.

6.1.2 ***Server Side.*** We conduct a similar analysis on the privacy-preserving impact of HTTP/2 features from the server perspective.

Table 7: Client-Side Defense Landscape with HTTP/2. H2PC vs. best performing defense (BBQ 1, 2, 3, 4). Macro-F1 and Top-5 are means; their 95% CIs are below 0.02 and omitted.

Dataset	Defense	F1	Top-5	$\mathcal{K}^*$	ΔUp	ΔDown	ΔT
Amz.	CL-TAM	0.24	0.51	38.4	3.3	3.2	1.4
	H2PC	0.32	0.60	20.1	2.1	2.0	0.4
BBC	CL-TAM	0.24	0.54	26.6	2.5	4.1	0.3
	H2PC	0.51	0.77	10.8	2.3	3.3	0.01
Reddit	CL-TAM	0.38	0.47	34.1	16.3	3.0	0.6
	H2PC	0.68	0.84	8.11	1.1	1.3	0.01
Udemy	CL-TAM	0.88	0.99	2.48	10.5	8.2	4.7
	H2PC	0.70	0.87	7.31	2.8	2.8	0.2
Wiki	CL-TAM	0.42	0.62	27.9	6.6	2.2	1.1
	H2PC	0.70	0.87	7.32	1.4	1.6	0.5

Server Opportunity 1: Randomizing HTTP/2's built-in feature behavior can improve web-browsing privacy.

A privacy-conscious HTTP/2 server (H2PS) can use:

- *Multiplexing & Prioritization.* The server can buffer multiple requests or delay streams, leading to unpredictable burst patterns.
- *Flow Control.* HTTP/2 servers can artificially constrain their transmission rate by maintaining an internal flow-control limit smaller than the receiver's advertised window, effectively under-utilizing the available window capacity.
- *Connection Probing.* Similar to clients, servers can send PING frames to disrupt burst patterns.

Server Opportunity 2: HTTP/2 primitives allow 1st Party servers to defend the entire webpage.

When a HTTP/2-conformant client prefetches suggested resources, servers can suggest noise traffic using mechanisms such as Server-Push or "103 Early Hints" (as with ALPaCA and SRV-Tamaraw). Notably, "103 Early Hints" [45] work across servers: a server can reference resources from any domain, which a client would fetch. This adds a new dimension to server-side defenses, enabling first parties to protect the entire webpage.

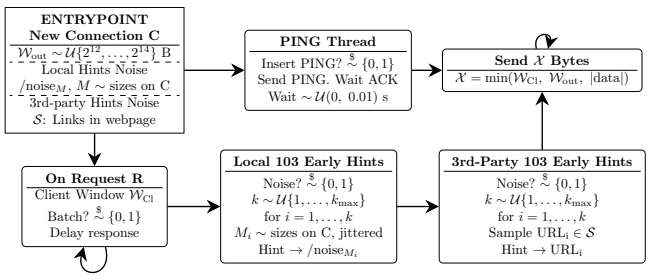


Figure 16: A privacy-conscious HTTP/2 server (H2PS) flow.

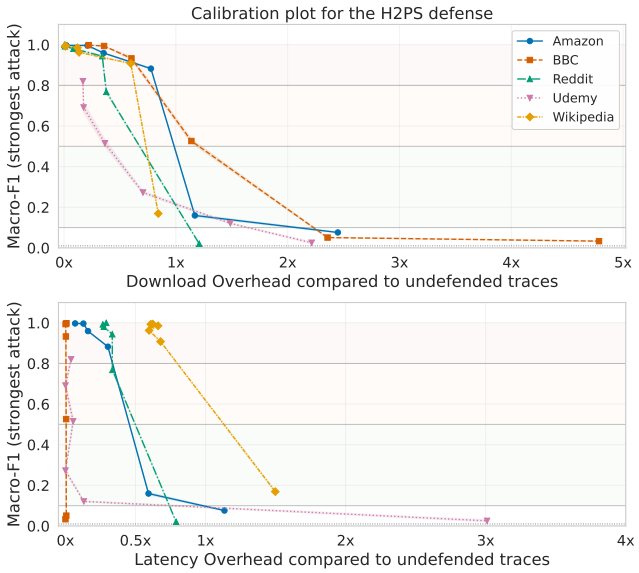


Figure 17: Calibration for the H2PS defense (BBQ 0). Strongest-attacker Macro-F1 per dataset against bandwidth (top) and latency (bottom) overhead. Horizontal lines mark the weak, moderate, and strong attacker thresholds; the dotted line is random guessing.

Figure 16 shows the H2PS defense workflow. For each new connection C to the 1st–Party (e.g., www.bbc.com), the server randomizes its outbound flow-control limit $\mathcal{W}_{\text{out}}$ and spawns an independent PING thread to disrupt burst patterns, similar to H2PC. For every incoming request, the server probabilistically issues two types of "103 Early Hints" before returning the actual response: (1) synthetic local hints, served directly by the defended 1st server; and (2) third-party hints, with real resources hosted on other CDN servers observed in the page load (e.g., by extracting them from the HTML). This is a key advantage of "Early Hints" over "Server Push": as Early Hints send only `Link` headers rather than actual content, the 1st-party server can hint resources on any origin without CDN cooperation or a shared proxy. Assuming client cooperation, the hint fetches are multiplexed with legitimate `HTTP/2` frames, perturbing the network metadata observed by a passive adversary. Requests are also probabilistically batched and delayed, leading to timing unpredictability.

For defense calibration (**BBQ 0**), H2PS varies the number of "103 Early Hints" per defended connection ($[1,1]$ to $[40,120]$), PING padding, and HPACK randomization at the strongest configurations. The eight candidate configurations use Early Hints ranges $[1,1]$, $[1,2]$, $[1,5]$, $[1,10]$, $[6,18]$, $[12,36]$, $[24,72]$, and $[40,120]$. The first configuration uses no PING padding; all remaining configurations use one PING, and HPACK randomization is enabled for the three strongest ranges, starting at $[12,36]$. Figure 17 shows that lighter H2PS configurations provide limited protection, with dataset-dependent knees at stronger configurations. Amazon and Reddit select the $[12,36]$ Early Hints range, reaching calibration Macro-F1 of 0.076 and 0.021, respectively. BBC and Udemy select $[6,18]$, reaching 0.051 and 0.121, as stronger configurations incur substantially higher overhead for limited additional benefit. Wikipedia requires $[24,72]$, where calibration Macro-F1 decreases from 0.169 at $[12,36]$ to 0.016. The calibration shows dataset-dependent knees: BBC and Udemy select $[6,18]$ Early Hints, Amazon and Reddit $[12,36]$, and Wikipedia $[24,72]$; the selected configurations yield calibration Macro-F1 ≤ 0.121 across all five datasets. All selected configurations use one PING, with HPACK randomization enabled for Amazon, Reddit, and Wikipedia.

Table 8: Server-Side Defense Landscape with `HTTP/2`. Comparison of deploying the strongest defense on the leakiest server compared to H2PS 1st Party (BBQ 1-4). Macro-F1 and Top-5 are means; their 95% CIs are below 0.01 and omitted.

Dataset	Defense	F1	Top-5	$\mathcal{K}^*$	ΔDown	ΔT
Amz.	TAM (CDN)	0.26	0.51	24.5	2.2	1.5
	H2PS	0.41	0.73	29.2	2.4	1.1
BBC	ALP (CDN)	0.87	0.99	2.3	12.1	0.5
	H2PS	0.18	0.39	42.5	2.4	0.0
Reddit	ALP (1st)	0.33	0.45	39.3	3.4	0.5
	H2PS	0.31	0.49	44.2	1.2	0.8
Udemy	TAM (1st)	0.41	0.54	14.6	3.7	1.5
	H2PS	0.52	0.79	13.2	1.5	0.1
Wiki	ALP (1st)	0.09	0.17	76.3	5.0	1.4
	H2PS	0.05	0.15	94.7	2.3	2.5

Table 8 summarizes the privacy–overhead trade-off of H2PS against the strongest single-server baseline (**BBQ 1–4**). For each dataset, the baseline defense (ALPaCA or SRV-Tamaraw) is deployed on the leakiest server, which may be either the 1st-party server or a CDN; H2PS, in contrast, is always deployed only at the 1st-party server and requires no third-party cooperation. Despite this constraint, H2PS keeps the attacker's estimated candidate set above 13 webpages across all five datasets. Its protection is also more consistent across datasets: H2PS reaches $\mathcal{K}^* = 13.2$–94.7, whereas the corresponding leakiest-server baselines range from 2.3 to 76.3. The gains are most pronounced on BBC and Wikipedia, while H2PS remains competitive on Reddit. Amazon presents a mixed trade-off: directly defending the leaky CDN yields lower F1 and Top-5, while H2PS achieves a larger candidate set (29.2 vs. 24.5). On Udemy, the leakiest-server baseline retains a small privacy advantage.

H2PS also offers a favorable overhead profile. On four of five datasets, it reduces downstream overhead by 54–80% relative to the corresponding leakiest-server baseline; on Amazon, the two are comparable (2.4 vs. 2.2). Latency is lower on Amazon, BBC, and Udemy, while Reddit and Wikipedia trade additional latency for comparable or stronger privacy. Overall, H2PS provides more consistent protection using only the 1st-party server, without requiring cooperation from third-party or CDN servers.

Table 9: Summary of the HTTP/2 WF defenses. For server-side baselines, $\mathcal{K}^*$ ranges use the best single-server placement (1st party or CDN) for each dataset.

Defense	$[\mathcal{K}^*_{\min} - \mathcal{K}^*_{\max}]$	Overhead	Coverage
Client-Side			
CL-TAM	$[2.5 - 38.4]$	High	**Page-wide**
FRONT	$[1.8 - 27.7]$	High	**Page-wide**
H2PC	$[7.3 - 20.1]$	Low	**Page-wide**
Server-Side			
SRV-TAM	$[1.7 - 24.5]$	High	Per-server
ALPaCA	$[2.3 - 76.3]$	High	Per-server
H2PS 1st P	$[13.2 - 94.7]$	Low	**Page-wide**

7 Conclusion

We show that HTTP/2 supports practical subpage fingerprinting defenses without requiring a multi-hop anonymity network. We demonstrate how established client- and server-side defenses can be emulated using HTTP/2 primitives and identify additional protocol features that improve their privacy–overhead trade-offs and deployment coverage. Further, we highlight overlooked HTTP/2 features that can significantly reduce client-side defense overhead or expand the coverage of server-side defenses.

Table 9 summarizes these trade-offs. On the *client side*, CL-TAM achieves the strongest privacy in several datasets but with high overhead and substantial cross-dataset variability, whereas H2PC provides a higher minimum candidate set (7.31) at lower cost and with page-wide coverage. On the *server side*, SRV-TAM and ALPaCA provide strong protection when deployed on the appropriate server, but remain placement-dependent and costly. H2PS instead extends protection page-wide from the 1st-party server alone, maintaining a candidate set above 13 webpages at lower overhead and without requiring coordination with third-party servers.

Finally, we introduced a blueprint for benchmarking and quality assurance, providing a structured way to assess fingerprinting defenses and their privacy–overhead trade-offs. Our evaluation shows that defense calibration and attacker hyperparameter tuning are integral to this assessment. More broadly, the variation in selected defense parameters and strongest attackers across datasets highlights the benefits of multi-dataset evaluation and suggests that defense configurations should be tailored to the target website, as conclusions drawn from other websites may not transfer reliably.

Acknowledgments

We thank the anonymous reviewers for their constructive feedback, which helped improve the paper.

References

[1] Ahmed Abusnaina, Rhongho Jang, Aminollah Khormali, et al. 2020. DFD: Adversarial Learning-based Approach to Defend Against Website Fingerprinting. In *IEEE INFOCOM*. 2459–2468. doi:10.1109/INFOCOM41043.2020.9155465

[2] Akamai Technologies. 2023. Improve UX with HTTP/2 Multiplexed Requests. https://www.akamai.com/blog/performance/improve-ux-with-http2-multiplexed-requests. Accessed: 2024-07-31.

[3] Khaled Al-Naami, Amir El-Ghamry, Md Shihabul Islam, et al. 2021. BiMorphing: A Bi-Directional Bursting Defense against Website Fingerprinting Attacks. *IEEE Transactions on Dependable and Secure Computing* 18, 2 (March 2021), 505–517. doi:10.1109/TDSC.2019.2907240

[4] David Belson and Lucas Pardue. 2023. Examining HTTP/3 usage one year on — blog.cloudflare.com. https://blog.cloudflare.com/http3-usage-one-year-on/

[5] Sanjit Bhat, David Lu, Albert Kwon, et al. 2019. Var-CNN: A Data-Efficient Website Fingerprinting Attack Based on Deep Learning. *Proc. Priv. Enhancing Technol.* 2019, 4 (2019), 292–310. doi:10.2478/POPETS-2019-0070

[6] Xiang Cai, Rishab Nithyanand, and Rob Johnson. 2014. CS-BuFLO: A Congestion Sensitive Website Fingerprinting Defense. In *Proceedings of the 13th Workshop on Privacy in the Electronic Society*. Association for Computing Machinery, New York, NY, USA, 121–130. doi:10.1145/2665943.2665949

[7] Xiang Cai, Rishab Nithyanand, Tao Wang, et al. 2014. A Systematic Approach to Developing and Evaluating Website Fingerprinting Defenses. In *ACM CCS*. 227–238. doi:10.1145/2660267.2660362

[8] Bogdan Cebere and Christian Rossow. 2024. Understanding Web Fingerprinting with a Protocol-Centric Approach. In *RAID*. 17–34. doi:10.1145/3678890.3678910

[9] Heyning Cheng and Ron Avnur. 1998. *Traffic Analysis of SSL Encrypted Web Browsing*. Project Paper. University of California, Berkeley.

[10] Giovanni Cherubin. 2017. Bayes, not Naïve: Security Bounds on Website Fingerprinting Defenses. *Proc. Priv. Enhancing Technol.* 2017, 4 (2017), 215–231. doi:10.1515/POPETS-2017-0046

[11] Giovanni Cherubin, Jamie Hayes, and Marc Juarez. 2017. Website Fingerprinting Defenses at the Application Layer. *Proc. Priv. Enhancing Technol.* 2017, 2 (2017), 186–203. doi:10.1515/POPETS-2017-0023

[12] Giovanni Cherubin, Rob Jansen, and Carmela Troncoso. 2022. Online Website Fingerprinting: Evaluating Website Fingerprinting Attacks on Tor in the Real World. In *USENIX Security Symposium*. 753–770. https://www.usenix.org/conference/usenixsecurity22/presentation/cherubin

[13] Cloudflare. 2026. Adoption & Usage Worldwide. https://radar.cloudflare.com/adoption-and-usage?dateRange=52w. Cloudflare Radar, accessed 2026-08-17.

[14] Scott E. Coull and Kevin P. Dyer. 2014. Traffic Analysis of Encrypted Messaging Services: Apple iMessage and Beyond. *Comput. Commun. Rev.* 44, 5 (2014), 5–11. doi:10.1145/2677046.2677048

[15] Thomas M Cover. 1999. *Elements of information theory*.

[16] Tianyu Cui, Gaopeng Gou, Gang Xiong, et al. 2021. SiamHAN: IPv6 Address Correlation Attacks on TLS Encrypted Traffic via Siamese Heterogeneous Graph Attention Network. In *USENIX Security Symposium*. 4329–4346. https://www.usenix.org/conference/usenixsecurity21/presentation/cui

[17] Thilini Dahanayaka, Guillaume Jourjon, and Suranga Seneviratne. 2020. Understanding Traffic Fingerprinting CNNs. In *IEEE LCN*. 65–76. doi:10.1109/LCN48667.2020.9314785

[18] Xinhao Deng, Qi Li, and Ke Xu. 2024. Robust and Reliable Early-Stage Website Fingerprinting Attacks via Spatial-Temporal Distribution Analysis. In *ACM CCS*. 1997–2011. doi:10.1145/3658644.3670272

[19] Xianwen Deng, Ruijie Zhao, Yanhao Wang, Mingwei Zhan, Zhi Xue, and Yijun Wang. 2025. Countmamba: A generalized website fingerprinting attack via coarse-grained representation and fine-grained prediction. In *IEEE S&P*. IEEE, 1419–1437.

[20] Kevin P. Dyer, Scott E. Coull, Thomas Ristenpart, et al. 2012. Peek-a-Boo, I Still See You: Why Efficient Traffic Analysis Countermeasures Fail. In *IEEE S&P*. 332–346. doi:10.1109/SP.2012.28

[21] Roy T. Fielding, Yves Lafon, and Julian F. Reschke. 2014. Hypertext Transfer Protocol (HTTP/1.1): Range Requests. *RFC* 7233 (June 2014). doi:10.17487/RFC7233

[22] Vincent Ghiëtte and Christian Doerr. 2020. Scaling website fingerprinting. In *IFIP Networking*. 199–207. https://ieeexplore.ieee.org/document/9142795

[23] Jiajun Gong and Tao Wang. 2020. Zero-delay Lightweight Defenses against Website Fingerprinting. In *USENIX Security Symposium*. 717–734. https://www.usenix.org/conference/usenixsecurity20/presentation/gong

[24] Jamie Hayes and George Danezis. 2016. k-fingerprinting: A Robust Scalable Website Fingerprinting Technique. In *USENIX Security Symposium*. 1187–1203. https://www.usenix.org/conference/usenixsecurity16/technical-sessions/presentation/hayes

[25] Andrew Hintz. 2002. Fingerprinting websites using traffic analysis. In *PETS*. Springer, 171–178.

[26] Paul Hoffman and Patrick McManus. 2018. DNS Queries over HTTPS (DoH). *RFC* 8484 (Oct. 2018). doi:10.17487/RFC8484

[27] James K. Holland and Nicholas Hopper. 2022. RegulaTor: A Straightforward Website Fingerprinting Defense. *Proc. Priv. Enhancing Technol.* 2022, 2 (2022), 344–362. doi:10.2478/POPETS-2022-0049

[28] Jana Iyengar and Martin Thomson. 2021. QUIC: A UDP-Based Multiplexed and Secure Transport. *RFC* 9000 (May 2021). doi:10.17487/RFC9000

[29] Marc Juarez, Mohsen Imani, Mike Perry, et al. 2015. WTF-PAD: Toward an Efficient Website Fingerprinting Defense for Tor. *CoRR* abs/1512.00524 (2015). arXiv:1512.00524 http://arxiv.org/abs/1512.00524

[30] Wladimir De la Cadena, Asya Mitseva, Jens Hiller, et al. 2020. TrafficSliver: Fighting Website Fingerprinting Attacks with Traffic Splitting. In *ACM CCS*. 1971–1985. doi:10.1145/3372297.3423351

[31] Shuai Li, Huajun Guo, and Nicholas Hopper. 2018. Measuring Information Leakage in Website Fingerprinting Attacks and Defenses. In *ACM CCS*. 1977–1992. doi:10.1145/3243734.3243832

[32] Jingyuan Liang, Chansu Yu, Kyoungwon Suh, et al. 2022. Tail Time Defense Against Website Fingerprinting Attacks. *IEEE Access* 10 (2022), 18516–18525. doi:10.1109/ACCESS.2022.3146236

[33] Weiran Lin, Sanjeev Reddy, and Nikita Borisov. 2019. Measuring the impact of HTTP/2 and server push on web fingerprinting. In *MADWeb*.

[34] Xinjie Lin, Gang Xiong, Gaopeng Gou, Zhen Li, Junzheng Shi, and Jing Yu. 2022. ET-BERT: A Contextualized Datagram Representation with Pre-training Transformers for Encrypted Traffic Classification. In *Proceedings of the ACM Web Conference 2022*. Association for Computing Machinery, New York, NY, USA, 633–642. doi:10.1145/3485447.3512217

[35] Chang Liu, Zigang Cao, Zhen Li, and Gang Xiong. 2018. LaFFT: Length-Aware FFT Based Fingerprinting for Encrypted Network Traffic Classification. In *IEEE ISCC*. 1–6. doi:10.1109/ISCC.2018.8538732

[36] Chang Liu, Longtao He, Gang Xiong, et al. 2019. FS-Net: A Flow Sequence Network For Encrypted Traffic Classification. In *IEEE INFOCOM*. 1171–1179. doi:10.1109/INFOCOM.2019.8737507

[37] David Lu, Sanjit Bhat, Albert Kwon, et al. 2018. DynaFlow: An Efficient Website Fingerprinting Defense Based on Dynamically-Adjusting Flows. In *ACM WPES*. 109–113. doi:10.1145/3267323.3268960

[38] Xiapu Luo, Peng Zhou, Edmond W. W. Chan, et al. 2011. HTTPOS: Sealing Information Leaks with Browser-side Obfuscation of Encrypted Flows. In *NDSS Symposium*. https://www.ndss-symposium.org/ndss2011/httpos-sealing-information-leaks-with-browser-side-obfuscation-of-encrypted-flows

[39] Mariano Di Martino, Peter Quax, and Wim Lamotte. 2019. Realistically Fingerprinting Social Media Webpages in HTTPS Traffic. In *ARES*. 54:1–54:10. doi:10.1145/3339252.3341478

[40] Mariano Di Martino, Pieter Robyns, Peter Quax, et al. 2018. IUPTIS: A Practical, Cache-resistant Fingerprinting Technique for Dynamic Webpages. In *WEBIST*. 102–112. doi:10.5220/0007226501020112

[41] Brad Miller, Ling Huang, Anthony D. Joseph, et al. 2014. I Know Why You Went to the Clinic: Risks and Realization of HTTPS Traffic Analysis. In *PETS (Lecture Notes in Computer Science, Vol. 8555)*. 143–163. doi:10.1007/978-3-319-08506-7_8

[42] Gargi Mitra, Prasanna Karthik Vairam, Patanjali Slpsk, et al. 2020. Depending on HTTP/2 for Privacy? Good Luck!. In *IEEE/IFIP DSN*. doi:10.1109/DSN48063.2020.00044

[43] Ricardo Morla. 2017. Effect of Pipelining and Multiplexing in Estimating HTTP/2.0 Web Object Sizes. *CoRR* abs/1707.00641 (2017). arXiv:1707.00641 http://arxiv.org/abs/1707.00641

[44] Milad Nasr, Alireza Bahramali, and Amir Houmansadr. 2021. Defeating DNN-Based Traffic Analysis Systems in Real-Time With Blind Adversarial Perturbations. In *USENIX Security Symposium*. 2705–2722. https://www.usenix.org/conference/usenixsecurity21/presentation/nasr

[45] Kazuho Oku. 2017. An HTTP Status Code for Indicating Hints. *RFC* 8297 (2017), 1–7. doi:10.17487/RFC8297

[46] Andriy Panchenko, Fabian Lanze, Jan Pennekamp, et al. 2016. Website Fingerprinting at Internet Scale. In *NDSS Symposium*. http://wp.internetsociety.org/ndss/wp-content/uploads/sites/25/2017/09/website-fingerprinting-internet-scale.pdf

[47] Performance Calendar. 2022. HTTP/3 Prioritization Demystified. https://calendar.perfplanet.com/2022/http-3-prioritization-demystified/. Accessed: 2024-07-30.

[48] Victor Le Pochat, Tom Van Goethem, Samaneh Tajalizadehkhoob, Maciej Korczyński, and Wouter Joosen. 2018. Tranco: A research-oriented top sites ranking hardened against manipulation. *arXiv preprint arXiv:1806.01156* (2018).

[49] Tobias Pulls. 2020. Towards Effective and Efficient Padding Machines for Tor. *CoRR* abs/2011.13471 (2020). arXiv:2011.13471 https://arxiv.org/abs/2011.13471

[50] Mohammad Saidur Rahman, Mohsen Imani, Nate Mathews, et al. 2021. Mockingbird: Defending Against Deep-Learning-Based Website Fingerprinting Attacks With Adversarial Traces. *IEEE Trans. Inf. Forensics Secur.* 16 (2021), 1594–1609. doi:10.1109/TIFS.2020.3039691

[51] Mohammad Saidur Rahman, Payap Sirinam, Nate Mathews, et al. 2020. Tik-Tok: The Utility of Packet Timing in Website Fingerprinting Attacks. *Proc. Priv. Enhancing Technol.* 2020, 3 (2020), 5–24. doi:10.2478/POPETS-2020-0043

[52] Eric Rescorla, Kazuho Oku, Nick Sullivan, and Christopher A. Wood. 2026. TLS Encrypted Client Hello. *RFC* 9849 (March 2026). doi:10.17487/RFC9849

[53] Vera Rimmer, Davy Preuveneers, Marc Juarez, et al. 2018. Automated Website Fingerprinting through Deep Learning. In *NDSS Symposium*. doi:10.14722/ndss.2018.23105

[54] Brian C Ross. 2014. Mutual information between discrete and continuous data sets. *PloS one* 9, 2 (2014), e87357.

[55] Amir Sabzi, Rut Vora, Swati Goswami, et al. 2024. NetShaper: A Differentially Private Network Side-Channel Mitigation System. In *USENIX Security Symposium*. https://www.usenix.org/conference/usenixsecurity24/presentation/sabzi

[56] Shawn Shan, Arjun Nitin Bhagoji, Haitao Zheng, et al. 2021. A Real-time Defense against Website Fingerprinting Attacks. *CoRR* abs/2102.04291 (2021). arXiv:2102.04291 https://arxiv.org/abs/2102.04291

[57] Meng Shen, Zhenbo Gao, Liehuang Zhu, et al. 2021. Efficient Fine-Grained Website Fingerprinting via Encrypted Traffic Analysis with Deep Learning. In *IEEE/ACM IWQoS*. 1–10. doi:10.1109/IWQOS52092.2021.9521272

[58] Meng Shen, Kexin Ji, Zhenbo Gao, et al. 2023. Subverting Website Fingerprinting Defenses with Robust Traffic Representation. In *USENIX Security Symposium*. 607–624. https://www.usenix.org/conference/usenixsecurity23/presentation/shen-meng

[59] Meng Shen, Yiting Liu, Siqi Chen, Liehuang Zhu, and Yuchao Zhang. 2019. Webpage Fingerprinting using Only Packet Length Information. In *IEEE ICC*. 1–6. doi:10.1109/ICC.2019.8761167

[60] Meng Shen, Yiting Liu, Liehuang Zhu, et al. 2021. Fine-Grained Webpage Fingerprinting Using Only Packet Length Information of Encrypted Traffic. *IEEE Trans. Inf. Forensics Secur.* 16 (2021), 2046–2059. doi:10.1109/TIFS.2020.3046876

[61] Sandra Siby, Ludovic Barman, Christopher A. Wood, et al. 2023. Evaluating practical QUIC website fingerprinting defenses for the masses. *Proc. Priv. Enhancing Technol.* 2023, 4 (2023), 79–95. doi:10.56553/POPETS-2023-0099

[62] Payap Sirinam, Mohsen Imani, Marc Juarez, et al. 2018. Deep Fingerprinting: Undermining Website Fingerprinting Defenses with Deep Learning. In *ACM CCS*. 1928–1943. doi:10.1145/3243734.3243768

[63] Jean-Pierre Smith, Luca Dolfi, Prateek Mittal, et al. 2022. QCSD: A QUIC Client-Side Website-Fingerprinting Defence Framework. In *USENIX Security Symposium*. 771–789.

[64] Qixiang Sun, Daniel R Simon, Yi-Min Wang, Wilf Russell, Venkata N Padmanabhan, and Lili Qiu. 2002. Statistical identification of encrypted web browsing traffic. In *IEEE S&P*. IEEE, 19–30.

[65] Martin Thomson and Cory Benfield. 2022. HTTP/2. *RFC* 9113 (2022), 1–78. doi:10.17487/RFC9113

[66] Thijs Van Ede, Riccardo Bortolameotti, Andrea Continella, et al. 2020. FlowPrint: Semi-Supervised Mobile-App Fingerprinting on Encrypted Network Traffic. In *NDSS Symposium*. doi:10.14722/ndss.2020.24412

[67] Alexander Veicht, Cédric Renggli, and Diogo Barradas. 2023. DeepSE-WF: Unified Security Estimation for Website Fingerprinting Defenses. *Proc. Priv. Enhancing Technol.* 2023, 2 (2023), 188–205. doi:10.56553/POPETS-2023-0047

[68] Kailong Wang, Junzhe Zhang, Guangdong Bai, et al. 2021. It's Not Just the Site, It's the Contents: Intra-domain Fingerprinting Social Media Websites Through CDN Bursts. In *The Web Conference*. 2142–2153. doi:10.1145/3442381.3450008

[69] Rong Wang, Zhen Ling, Guangchi Liu, Shaofeng Li, Junzhou Luo, and Xinwen Fu. 2026. Cease at the Ultimate Goodness: Towards Efficient Website Fingerprinting Defense via Iterative Mutual Information Minimization.. In *NDSS*.

[70] Tao Wang. 2020. High Precision Open-World Website Fingerprinting. In *IEEE S&P*. 152–167. doi:10.1109/SP40000.2020.00015

[71] Tao Wang and Ian Goldberg. 2017. Walkie-Talkie: An Efficient Defense Against Passive Website Fingerprinting Attacks. In *USENIX Security Symposium*. 1375–1390. https://www.usenix.org/conference/usenixsecurity17/technical-sessions/presentation/wang-tao

[72] Wikipedia contributors. [n. d.]. HTTP/2 Server Push. https://en.wikipedia.org/wiki/HTTP/2_Server_Push. Accessed: 2026-04-23.

[73] Renjie Xie, Jiahao Cao, Enhuan Dong, et al. 2023. Rosetta: Enabling Robust TLS Encrypted Traffic Classification in Diverse Network Environments with TCP-Aware Traffic Augmentation. In *USENIX Security Symposium*. 625–642. https://www.usenix.org/conference/usenixsecurity23/presentation/xie

[74] Ziqing Zhang, Cuicui Kang, Gang Xiong, et al. 2019. Deep Forest with LRRS Feature for Fine-grained Website Fingerprinting with Encrypted SSL/TLS. In *ACM CIKM*. 851–860. doi:10.1145/3357384.3357993

[75] Xiyuan Zhao, Xinhao Deng, Qi Li, Yunpeng Liu, Zhuotao Liu, Kun Sun, and Ke Xu. 2024. Towards fine-grained webpage fingerprinting at scale. In *ACM CCS*. 423–436.

A Open Science

Code availability. We release the code for defense calibration, the WF defenses auditing tool (`wfaudit`), real-world data collection and replay, the `HTTP/2` client- and server-side defenses, and the dataset creation and benchmarking pipeline at https://github.com/bcebere/Understanding-the-Privacy-Preserving-Potential-of-HTTP2-Against-Webpage-Fingerprinting.

B Ethical Considerations

Data Collection. All data used in this work was collected from publicly accessible websites using automated browsing without bypassing authentication, paywalls, or access controls. No personal data, user accounts, or sensitive identifiers were collected; only

client–server traffic from scripted, non-authenticated sessions was recorded.

For each case study, we saved the request order and the downloaded resources to replay the content locally under various client or server defenses.

Stakeholders and Impacts. This work involves three primary stakeholder groups, as follows:

- *End Users.* Common end users, including privacy-sensitive populations (such as journalists, activists, and users of privacy-enhancing technologies), are the primary stakeholders. Our experiments did not involve real users or user-generated traffic. While publication of fingerprinting techniques may increase the risk of traffic analysis by adversaries, the defensive insights provided by this work aim to strengthen user privacy in the long term.
- HTTP/2 *Clients or Servers Developers.* Developers of HTTP/2 libraries may be impacted by our findings. This work identifies potential privacy weaknesses and benefits when employing various HTTP/2 features.
- *Researchers and Practitioners.* The research community benefits from reproducible measurements and benchmarks. To support responsible reuse, we release our code for data collection and the benchmarking framework (Section A). The authors bear responsibility for accurate threat modeling and harm mitigation.

Research Impact. This work has both positive and negative impacts, affecting the stakeholders.

- *Positive Impacts.* First, we emulate concrete defenses for strengthening HTTP/2 clients and servers. Second, our open-source implementation enables practitioners to audit, reproduce, and extend our findings (Section A).
- *Negative Impacts.* As with prior fingerprinting research, the techniques discussed could be misused for surveillance, targeted advertising, or aggressive monitoring. These risks reflect the dual-use nature of traffic analysis research.

Mitigations. To mitigate potential harms, we implement and evaluate defenses alongside attacks. Specifically, we implement defensive mechanisms at both the client and the server levels, using various HTTP/2 features.

C Generative AI Usage

Large Language Models were used for limited editorial assistance, related-work search support, and code review/debugging. All generated text was reviewed and edited by the authors, all references were independently verified, and all research code was written, verified, and validated by the authors. No LLM was used to generate original research ideas or results forming the scientific contributions of this paper. The authors take full responsibility for the accuracy, originality, and integrity of the work.

D Data Collection Methodology

Given that we benchmark defenses at both the server and the client levels, we cannot use the real website deployments for experiments. Instead, we collect browser traces for each webpage and replay them using the HTTP/2 client and server described in Section D.2.

D.1 Baseline Browser Crawlers

The browser traces are collected using a headless Chromium browser automated via Playwright. For each URL, a new browser context is created with caching disabled, and the page is loaded until the `domcontentloaded` event fires. Two traces are recorded in parallel: a client-side trace logging each request's URL and headers, and a server-side trace logging each response's URL, status code, content type, response headers, and round-trip duration (measured as wall-clock time between request dispatch and response receipt). Both client and server browser traces are serialized to JSON and saved to disk. The raw response body of each resource is saved to disk and referenced by path in the server trace JSON.

These traces (request order and response content) are replayed in a Python HTTP/2 client - server environment, with various defenses enabled. The code responsible for collecting the browser traces is available in "datasets/browser_crawlers" in the code repository.

D.2 HTTP/2 Client - Server Simulation

The client-server code used to replay the browser traces is available in the code repository, with a proof-of-concept standalone library 'h2deflib'. The HTTP/2 clients and server (and their defenses) are implemented using the `h2` Python library, version 4.1.0. The `h2` library is a pure-Python, fully compliant implementation (RFC 9113 [65]) of the HTTP/2 protocol, that provides the low-level building blocks necessary to implement HTTP/2 clients and servers without requiring a specific I/O framework.

D.3 PCAP Traces Capture

To create the datasets for each benchmark, we replay the previously captured browser traces using the client–server setup described in Section D.2. The client and server run in separate Docker containers connected through a Docker virtual network; traffic is therefore exchanged between the two container network namespaces rather than over the host loopback interface.

Concretely, the `client_runner.py` script automates the capture of network traffic during replay. At startup, it loads the pre-captured browser data (Section D.1), including the requests and response bodies associated with each webpage. For each (webpage, repeat) pair, the script starts a Scapy `AsyncSniffer` on the client-side network interface and replays the webpage's HTTP/2 requests against the server container. Requests are grouped by connection (i.e., by domain), and the configured client-side and server-side defenses are applied during replay. Once the replay completes, the sniffer is stopped, and the captured packets are stored in a PCAP file for subsequent processing by the PCAP parsing pipeline.

D.4 Evaluation Datasets Creation

The PCAP traces are parsed and converted into two distinct evaluation datasets: a 2D representation and a 3D representation.

For 2D datasets (used by k-FP and WeFDE), each trace is loaded as a two-column CSV of timestamps and signed packet sizes, from which a flat 1D feature vector is extracted per trace covering packet counts, inter-packet timing, burst statistics, and CUMUL features. Stacking these vectors across all traces yields a 2D feature matrix of shape (n_traces, $\text{LIM}_{\text{conns}} * \text{n_features}$).

For 3D datasets (used by DF, VarCNN, RobustFP, Holmes and DeepSE-WF), each trace is converted into two channels: a signed timing channel (sign × timestamp) and a signed size channel (sign × |size|/2000), each padded or truncated to `feature_length` (set adaptively as the median non-zero trace length plus 50, capped at the specified maximum 5, 000). The two channels are stacked along axis 0 to give a per-trace tensor of shape (2, `feature_length`). Collecting all traces yields a 3D tensor of shape (n_samples, 2, `feature_length`), which is then standardized per channel across samples and time positions using the global mean and standard deviation.

The code responsible for parsing the traces and creating the datasets is available in the code repository, in "wfaudit/src/wfaudit/parser.py".

E Security Estimators Details

We employ two categories of security estimators: (1) *fingerprinting classifiers* that measure defense effectiveness through classification performance, and (2) *information-theoretic estimators* that quantify residual information leakage independently of specific attack strategies.

E.1 The Machine-Learning Estimators

We first describe the fingerprinting classifiers used in this study, together with their hyperparameter search spaces. To account for distribution shifts introduced by the defenses, we tune classifier hyperparameters independently for each dataset and defense configuration.

E.1.1 K-Fingerprinting [24]. k-FP extracts hand-crafted features from labeled network traces and trains a random decision forest classifier. Each trace is then represented by the vector of leaf-node identifiers. This compact fingerprint is then matched against known fingerprints using a nearest-neighbor approach to identify the visited site.

For hyperparameter search, we tune the number of trees in the random forest and the number of nearest neighbors used for classification. We search $n_{\text{trees}} \in \{50, 100, \ldots, 500\}$ and $k \in \{2, \ldots, 15\}$. These parameters control, respectively, the complexity of the learned fingerprint representation and the resolution of the neighbor-based voting stage.

E.1.2 Deep-FP [62]. DF uses a deep convolutional neural network to learn features directly from raw traces, without relying on hand-crafted features (unlike K-FP). The original implementation is available at github.com/deep-fingerprinting/df.

The DF neural network architecture consists of four convolutional blocks, each with two `Conv1d` layers of kernel size 5 and same padding, ELU activations ($\alpha = 1.0$), and a dropout rate of 0.1. The channel depths double across blocks: $32 \to 64 \to 128 \to 256$. A global average pooling layer is followed by a two-layer embedding head that projects to `embedding_size` = 512 dimensions via a `ReLU` activation and dropout ($p = 0.1$), and a classification head with dropout ($p = 0.5$).

For hyperparameter search, we tune the learning rate, weight decay, classifier dropout, and batch size. The learning rate is searched logarithmically over $[10^{-4}, 5 \times 10^{-3}]$; weight decay over $\{0, 10^{-6}, 10^{-5}, 10^{-4}, 10^{-3}, 10^{-2}\}$; classifier dropout over $[0.3, 0.7]$; and batch size over $\{64, 128, 200, 256\}$.

E.1.3 VarCNN [5]. VarCNN is a data-efficient website-fingerprinting attack that uses a ResNet-based CNN, which leads to better performance with fewer training traces (compared to DF). The original implementation is available at github.com/sanjit-bhat/Var-CNN.

The VarCNN classifier is built on a ResNet-18 backbone with four stages of $[2, 2, 2, 2]$ residual blocks, each consisting of two `Conv1d` layers of kernel size 3 with batch normalization ($\varepsilon = 10^{-5}$) and ReLU activations. The input embedding uses a `Conv1d` layer of kernel size 7 and stride 2, followed by batch normalization, ReLU, and max pooling (kernel size 3, stride 2). Channel depths double across stages: $64 \to 128 \to 256 \to 512$. Global average pooling is applied after the final stage, followed by a two-layer embedding head that projects $512 \to 1024 \to$ `embedding_size` (= 512) with ReLU and dropout ($p = 0.1$), and a classification head with ReLU, dropout ($p = 0.1$), and a linear output layer.

For hyperparameter search, we tune the learning rate, weight decay, dropout, and batch size. The learning rate is searched logarithmically over $[10^{-4}, 5 \times 10^{-3}]$; weight decay over $\{0, 10^{-6}, 10^{-5}, 10^{-4}, 10^{-3}, 10^{-2}\}$; dropout over $[0.1, 0.5]$; and batch size over $\{64, 128, 200, 256\}$.

E.1.4 Holmes [18]. Holmes is a method focusing on early-stage website fingerprinting. The original implementation is available at github.com/Xinhao-Deng/Website-Fingerprinting-Library.

The Holmes classifier uses a four-stage convolutional encoder (`conv_num_layers` = 4), where each stage consists of a residual `ConvBlock1d` with two `Conv1d` layers of kernel size 3, same padding, batch normalization, and ReLU activations, plus a 1×1 projection shortcut when channel dimensions change. Between stages, max pooling (kernel size 3) and dropout ($p = 0.3$) are applied. Channel depths follow a doubling schedule capped at the embedding size: $128 \to 128 \to 128 \to 128$ (since `emb_size` = 128). Global average pooling is applied after the final stage, followed by a classification head with dropout ($p = 0.3$) and a linear output layer.

For hyperparameter search, we tune the learning rate, weight decay, dropout, and batch size using the same ranges as VarCNN: learning rate in $[10^{-4}, 5{\times}10^{-3}]$ on a logarithmic scale, weight decay in $\{0, 10^{-6}, 10^{-5}, 10^{-4}, 10^{-3}, 10^{-2}\}$, dropout in $[0.1, 0.5]$, and batch size in $\{64, 128, 200, 256\}$.

E.1.5 RobustFP-CNN [58]. Robust Fingerprinting combines a dedicated traffic representation with a CNN classifier. In our evaluation, we use its CNN architecture with our packet representation rather than reproducing the complete Robust Fingerprinting preprocessing pipeline; we therefore refer to this classifier as *RobustFP-CNN*. The original Robust Fingerprinting implementation is available at github.com/robust-fingerprinting/RF.

The RobustFP-CNN classifier processes input through two sequential stages. The first is a 2D convolutional frontend with two pairs of `Conv2d` layers (kernel size $(3, 6)$, same padding), channel depths $1 \to 32 \to 64$, max pooling and dropout ($p = 0.1$) between pairs. The second is a 1D convolutional backend with channel configuration $[128, 128, \texttt{M}, 256, 256, \texttt{M}, 512, n_{\text{classes}}]$, where `M` denotes max pooling with dropout ($p = 0.3$), and each layer uses kernel size 3. Global average pooling produces the final logits.

For hyperparameter search, we tune the learning rate, weight decay, convolutional dropout, and batch size. The learning rate is searched logarithmically over $[10^{-4}, 5\times10^{-3}]$; weight decay over $\{0, 10^{-6}, 10^{-5}, 10^{-4}, 10^{-3}, 10^{-2}\}$; convolutional dropout over $[0.1, 0.5]$; and batch size over $\{64, 128, 200, 256\}$.

All CNN-based methods are modified to also process the packet-length information, which is informative in our datasets (and constant per `Tor` cell in the original implementations).

E.2 Information Leakage Estimators

E.2.1 WeFDE [31]. estimates the mutual information using manually selected features. The original implementation is available at github.com/s0irrlor7m/InfoLeakWebsiteFingerprint, and a Python version is available at github.com/notem/reWeFDE.

The WeFDE information leakage estimator uses the following hyperparameters: Bandwidth selection in the KDE uses the Hall plug-in method, with a rule-of-thumb fallback; Individual feature leakages are estimated using `n_samples` = 5,000 Monte Carlo samples, while the final joint cluster leakage uses `n_samples` = 50,000. The top `topn` = 20 features by individual leakage are selected for joint analysis, after pruning redundant features whose normalized mutual information exceeds `nmi_threshold` = 0.7.

E.2.2 DeepSE-WF [67]. estimates the mutual information and the Bayes error by using specialized kNN-based estimators on learned latent feature spaces. The original implementation is available at github.com/veichta/DeepSE-WF.

DeepSE-WF estimates mutual information by training an embedding model and applying k-NN estimators. The embedding backbone is DF with `embedding_size` = 512, `dropout` = 0.1, trained with `batch_size` = 200 and input sequences of length = 5,000. The dataset is split into train, validation, and two held-out test sets via stratified k-fold cross-validation (`k_fold` = 5); in each fold, the embedding model is trained on the training split and the two test splits are used to compute pairwise k-NN distance matrices. MI is then estimated in both directions (test1→test2 and test2→test1) and averaged. The k-NN estimator uses `squared_l2` distance, with `mi_k` = 5 neighbours for mutual information.

All these models are available in the "wfaudit" folder in the repository.

Table 11: Hyperparameter tuning on the *BBC Dataset*. Abbreviations: batch size → bs; dropout → do; learning rate → lr; weight decay → wd.

Defense	Best Model	Selected parameters
Client-side		
HTTPOS	k-FP	trees 350, k 9
LLaMA	RobustFP-CNN	bs 64, do .448, lr 9.2e-4, wd 0
FRONT	RobustFP-CNN	bs 64, do .457, lr 8.6e-4, wd 0
CL-Tamaraw	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
H2PC	RobustFP-CNN	bs 64, do .457, lr 8.6e-4, wd 0
Server-side		
SRV-ALPaCA (1st)	RobustFP-CNN	bs 64, do .457, lr 8.6e-4, wd 0
SRV-ALPaCA (3rd)	RobustFP-CNN	bs 64, do .448, lr 9.2e-4, wd 0
SRV-ALPaCA (all)	RobustFP-CNN	bs 64, do .448, lr 9.2e-4, wd 0
SRV-Tamaraw (1st)	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
SRV-Tamaraw (3rd)	Holmes	bs 128, do .124, lr 1.1e-3, wd 1.0e-6
SRV-Tamaraw (all)	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
H2PS (1st)	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6

Table 12: Hyperparameter tuning on the *Reddit Dataset*. Abbreviations: batch size → bs; dropout → do; learning rate → lr; weight decay → wd.

Defense	Best Model	Selected parameters
Client-side		
HTTPOS	RobustFP-CNN	bs 64, do .457, lr 8.6e-4, wd 0
LLaMA	Holmes	bs 128, do .124, lr 1.1e-3, wd 1.0e-6
FRONT	RobustFP-CNN	bs 64, do .457, lr 8.6e-4, wd 0
CL-Tamaraw	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
H2PC	RobustFP-CNN	bs 64, do .457, lr 8.6e-4, wd 0
Server-side		
SRV-ALPaCA (1st)	RobustFP-CNN	bs 64, do .448, lr 9.2e-4, wd 0
SRV-ALPaCA (3rd)	Holmes	bs 128, do .124, lr 1.1e-3, wd 1e-6
SRV-ALPaCA (all)	RobustFP-CNN	defaults kept
SRV-Tamaraw (1st)	Holmes	bs 128, do .124, lr 1.1e-3, wd 1e-6
SRV-Tamaraw (3rd)	Holmes	bs 128, do .124, lr 1.1e-3, wd 1e-6
SRV-Tamaraw (all)	Holmes	bs 128, do .124, lr 1.1e-3, wd 1e-6

Table 13: Hyperparameter tuning on the *Udemy Dataset*. Abbreviations: batch size → bs; dropout → do; learning rate → lr; weight decay → wd.

Defense	Best Model	Selected parameters
Client-side		
HTTPOS	Holmes	bs 128, do .124, lr 1.1e-3, wd 1.0e-6
FRONT	Holmes	bs 128, do .124, lr 1.1e-3, wd 1.0e-6
LLaMA	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
CL-Tamaraw	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
H2PC	RobustFP-CNN	bs 64, do .448, lr 9.2e-4, wd 0
Server-side		
SRV-ALPaCA (1st)	RobustFP-CNN	defaults kept
SRV-ALPaCA (3rd)	RobustFP-CNN	bs 64, do .448, lr 9.2e-4, wd 0
SRV-ALPaCA (all)	Holmes	bs 256, do .148, lr 4.6e-3, wd 1e-6
SRV-Tamaraw (1st)	Holmes	bs 128, do .124, lr 1.1e-3, wd 1e-6
SRV-Tamaraw (3rd)	Holmes	bs 128, do .124, lr 1.1e-3, wd 1e-6
SRV-Tamaraw (all)	k-FP	n_{trees} 350, k 9

Table 14: Hyperparameter tuning on the *Wikipedia Dataset*. Abbreviations: batch size → bs; dropout → do; learning rate → lr; weight decay → wd.

Defense	Best Model	Selected parameters
Client-side		
HTTPOS	RobustFP-CNN	bs 64, do .448, lr 9.2e-4, wd 0
LLaMA	RobustFP-CNN	bs 64, do .457, lr 8.6e-4, wd 0
FRONT	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
CL-Tamaraw	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
H2PC	RobustFP-CNN	bs 64, do .448, lr 9.2e-4, wd 0
Server-side		
SRV-ALPaCA (1st)	k-FP	trees 50, k 3
SRV-ALPaCA (3rd)	RobustFP-CNN	bs 64, do .457, lr 8.6e-4, wd 0
SRV-ALPaCA (all)	RobustFP-CNN	defaults kept
SRV-Tamaraw (1st)	RobustFP-CNN	bs 64, do .457, lr 8.6e-4, wd 0
SRV-Tamaraw (3rd)	RobustFP-CNN	bs 64, do .448, lr 9.2e-4, wd 0
SRV-Tamaraw (all)	RobustFP-CNN	bs 64, do .448, lr 9.2e-4, wd 0

Table 10: Hyperparameter tuning on the *Amazon Dataset*. Abbreviations: batch size → bs; dropout → do; learning rate → lr; weight decay → wd.

Defense	Best Model	Selected parameters
Client-side		
HTTPOS	RobustFP-CNN	bs 64, do .448, lr 9.2e-4, wd 0
LLaMA	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
FRONT	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
CL-Tamaraw	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
H2PC	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
Server-side		
SRV-ALPaCA (1st)	RobustFP-CNN	bs 64, do .457, lr 8.6e-4, wd 0
SRV-ALPaCA (3rd)	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
SRV-ALPaCA (all)	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
SRV-Tamaraw (1st)	RobustFP-CNN	bs 64, do .165, lr 3.4e-4, wd 1.0e-4
SRV-Tamaraw (3rd)	Holmes	bs 256, do .147, lr 4.6e-3, wd 1.0e-6
SRV-Tamaraw (all)	Holmes	bs 128, do .124, lr 1.1e-3, wd 1.0e-6

F Security Estimators Hyperparameter Tuning

We implement hyperparameter optimization using Optuna. We tune each attacker independently for each dataset–defense pair using a separate Optuna study, with Macro-F1 on a stratified held-out validation split as the optimization objective. To reduce tuning cost, each search uses up to 150 traces per webpage, of which 20% are reserved for validation.

Before optimization, we evaluate the attacker's default configuration on the same tuning split. We retain the optimized parameters only when the best Optuna trial achieves a higher Macro-F1 than the default configuration; otherwise, we preserve the default parameters. We then retrain the selected configuration and evaluate it on the full dataset using the same benchmarking procedure as the remaining experiments.

The following tables (Table 10, Table 11, Table 12, Table 13, Table 14) report, for each dataset–defense pair, the strongest attacker

after tuning and the hyperparameters selected for that attacker. We abbreviate batch size as *bs*, dropout as *do*, learning rate as *lr*, and weight decay as *wd*.